

Etica, Società e Privacy

Note Complete del Corso

Università di Torino – Magistrale Informatica – A.A. 2024/2025

Indice

1	Privacy: Definizioni e Leggi	2
1.1	Cos'è la Privacy?	2
1.2	Perché la Privacy è Importante?	2
1.3	Privacy vs. Sicurezza	3
1.4	Tipi di Privacy	4
1.5	Privacy negli Stati Uniti	4
1.6	Privacy nell'Unione Europea	5
1.6.1	Data Protection Directive 95/46/EC	5
1.6.2	Privacy in Italia	7
1.6.3	General Data Protection Regulation (GDPR)	7
1.7	Accordi Transnazionali EU-USA	11
1.8	AI Act (Agosto 2024)	11
1.9	Digital Services Act (DSA, 2022)	12
1.10	Data Act (settembre 2025)	13
1.11	Digital Omnibus (proposta novembre 2025)	13
2	Big Data e Minacce alla Privacy	14
2.1	Il Problema dei Big Data	14
2.2	Deanonimizzazione	15
3	Sistemi Informativi e Privacy	16
3.1	Controllo degli Accessi	17
3.1.1	RBAC – Role Based Access Control	18
3.1.2	ABAC – Attribute Based Access Control	18
3.2	Pseudoanonimizzazione con Crittografia	20
3.3	Auditing	22
4	Controllo del Rilascio di Informazioni Statistiche (SDC)	24
4.1	Disclosure	24
4.2	Metodi SDC per Macrodata	26
4.3	Metodi SDC per Dati Interrogabili (Query)	26
4.4	Metodi SDC per Microdata	26
4.5	Misura della Perdita di Informazioni: KL e JS	27
5	Framework di Anonimizzazione	28
5.1	Il Problema dell'Anonimità e il Linking Attack	28
5.2	K-Anonymity	29
5.2.1	Algoritmo di Samarati	31
5.2.2	Algoritmo Incognito	32

5.3	Oltre la K-Anonymity	33
5.3.1	Attacchi alla K-Anonymity	33
5.3.2	L-Diversity	33
5.3.3	δ -Presence	35
6	Privacy Differenziale	37
6.1	Definizione Formale	37
6.2	Meccanismo di Laplace	39
6.3	Meccanismo Esponenziale	40
6.4	Teoremi Fondamentali	40
6.5	(ε, δ) -Differential Privacy	41
6.6	Scenario Interattivo vs. Non-Interattivo	42
6.7	Curatore Non Fidato e Local Differential Privacy	42
6.8	Local Differential Privacy (LDP)	43
6.9	Machine Learning e Differential Privacy	44
7	Privacy in Sistemi Distribuiti	44
7.1	Il Problema	44
7.2	Secure Multiparty Computation (SMC)	45
7.2.1	Protocollo di Yao per Due Parti	46
7.2.2	Privacy Preserving ID3	47
7.3	Altri Approcci	48
8	Fairness e Discriminazione	49
8.1	Introduzione alla Fairness	49
8.2	Machine Learning e Fairness	50
8.3	Discriminazione e Misure di Discriminazione	50
8.3.1	Egalitarismo	51
8.3.2	Criteri di Fairness (Metriche)	51
8.3.3	Interventi di Fairness	52

1 Privacy: Definizioni e Leggi

1.1 Cos'è la Privacy?

La privacy è un concetto fondamentale con diverse definizioni complementari:

Definizione: Definizioni di Privacy

- **Warren & Brandeis (1890)**: *"The right to be alone"* – uno dei saggi più influenti nella storia del diritto americano; gli autori cercavano di trovare una base giuridica per proteggere la privacy nell'ambito delle leggi e dei principi già esistenti. Esempi di applicazione: il diritto di una persona di scegliere la solitudine lontano dall'attenzione degli altri; il diritto di essere immune dallo scrutinio o dall'essere osservati in contesti privati, come la propria abitazione.
- **Godkin (1880)**: *"Nothing is better worthy of legal protection than private life, or the right of every man to keep his affairs to himself, and to decide for himself to what extent they shall be the subject of public observation and discussion."* – accesso limitato alle informazioni personali.
- **Bok (1989)**: *"The condition of being protected from unwanted access by others – either physical access, personal information, or attention."* – protezione da accessi indesiderati.
- **Westin & Blom-Cooper (1970)**: *"Privacy is the claim of individuals, groups, or institutions to determine for themselves when, how, and to what extent information about them is communicated to others."* – controllo sull'informazione.
- **Fried (1968)**: *"Privacy is not simply an absence of information about us in the minds of others; rather it is the control we have over information about ourselves."* – controllo sulle proprie informazioni.
- **FIPS PUB 41 (NIST – Computer Security Guidelines for Implementing the Privacy Act of 1974)**: *"The right of an entity to determine the degree to which it will interact with its environment, including the degree to which the entity is willing to share its personal information with others."*
- **ISO**: Il diritto di un individuo a controllare o influenzare quali informazioni collegate a loro possono essere collezionate e salvate.

Definizione: Definizione Operativa Adottata

La privacy è l'abilità di una persona di:

1. Controllare la disponibilità di *informazioni* su sé stessa e la propria *esposizione*.
2. Funzionare *anonimamente* nella società.

1.2 Perché la Privacy è Importante?

La privacy è importante per molteplici ragioni:

- **Sentimenti individuali**: non confortabile essere sorvegliati; rischio di furto d'identità e uso improprio dei dati.
- **Esigenze aziendali**: le aziende devono proteggere la reputazione, soddisfare i clienti e rispettare le leggi.

- **Dignità umana:** Stefano Rodatà associa la privacy alla dignità umana – la perdita dei dati personali ha un costo immenso.
- **Libertà civile:** come sottolinea Edward Snowden, rinunciare alla privacy non è “non avere nulla da nascondere”, ma rinunciare a un diritto fondamentale. Glenn Greenwald – uno dei primi giornalisti ad avere accesso ai file Snowden e a scrivere delle estese attività di sorveglianza degli USA sui cittadini privati – sostiene nel suo TED talk che la privacy è fondamentale **anche se non si ha “nulla da nascondere”**: la sorveglianza di massa altera il comportamento delle persone e distrugge la libertà di pensiero.

Citazioni di Stefano Rodatà:

- *“Emerge un legame profondo tra libertà, dignità e privacy, che ci impone di guardare a quest’ultima al di là della sua storica definizione come diritto ad essere lasciato solo.”*
- *“Quale dignità rimane ad una persona divenuta prigioniera di un passato interamente in mani altrui, di cui deve rassegnarsi ad essere espropriato?”*

Privacy sotto attacco – statistiche: Nel 1996, il 24% degli americani dichiarava di aver subito una violazione della propria privacy (vs. il 19% nel 1978). Questo evidenzia una crescente erosione della privacy nonostante (o a causa di) l’avanzamento tecnologico.

1.3 Privacy vs. Sicurezza

Definizione: Privacy vs. Sicurezza (Security)

Privacy e sicurezza informatica sono concetti distinti ma interconnessi:

- **Privacy:** il diritto di un individuo di **controllare le proprie informazioni personali** – chi può accedervi, come vengono usate, e quando vengono condivise. È un *diritto* (o interesse legittimo) dell’individuo.
- **Sicurezza (Security):** insieme di **meccanismi tecnici e organizzativi** per proteggere dati e sistemi da accessi non autorizzati, modifiche o distruzione. Si articola nella **triade CIA**:
 1. **Confidentiality** (Riservatezza): solo le entità autorizzate accedono ai dati.
 2. **Integrity** (Integrità): i dati non vengono alterati in modo non autorizzato.
 3. **Availability** (Disponibilità): i dati sono accessibili quando necessario dagli utenti autorizzati.

Nota: Relazione tra Privacy e Sicurezza

La sicurezza è una condizione **necessaria ma non sufficiente** per la privacy:

- **Sicurezza senza privacy:** un’azienda può proteggere tecnicamente i dati degli utenti (buona sicurezza) ma venderli a terzi o usarli per finalità non dichiarate (violazione della privacy). ⇒ la sicurezza non implica la privacy.
- **Privacy senza sicurezza:** se un sistema non è sicuro, qualunque garanzia di privacy è illusoria – chi vuole può accedere ai dati senza autorizzazione. ⇒ non si può avere privacy reale senza sicurezza.

Sintesi: la privacy riguarda il *diritto* al controllo delle informazioni (scopo, uso, destinatari); la sicurezza fornisce i *meccanismi* per proteggere fisicamente quei dati. Entrambe

sono necessarie: la sicurezza tutela i dati dai *malintenzionati esterni*, la privacy tutela l'individuo anche dai *soggetti autorizzati* che potrebbero abusarne.

Esempio: Privacy vs. Sicurezza – casi pratici

- **NSA/PRISM**: sistema di sorveglianza con alta sicurezza informatica, ma che viola la privacy dei cittadini accedendo legalmente (o illegalmente) ai loro dati.
- **Cambridge Analytica**: i dati erano tecnicamente “sicuri” sui server di Facebook, ma sono stati condivisi senza adeguato consenso – violazione di privacy, non di sicurezza.
- **Data Breach**: violazione sia della sicurezza (accesso non autorizzato) che della privacy (esposizione dei dati personali).

1.4 Tipi di Privacy

- **Political privacy**: protezione delle opinioni e attività politiche.
- **Consumer privacy**: tutela dei dati dei consumatori da uso commerciale.
- **Medical privacy**: riservatezza dei dati sanitari.
- **Private property**: protezione dei beni personali.
- **Information/Data privacy**: gestione e tutela delle informazioni personali digitali.

Definizione: Data Privacy

Il problema della data privacy emerge quando dei dati unicamente associabili a un individuo sono collezionati e salvati. Le fonti più comuni includono: record sanitari, investigazioni criminali, transazioni finanziarie, tratti biologici/genetici, residenza/posizione geografica, geolocalizzazione, utilizzo del web e cookies.

La sfida della data privacy è trovare modi per condividere dati proteggendo le informazioni che permettono di identificare una determinata persona.

1.5 Privacy negli Stati Uniti

Negli USA **non esiste una legge unificata** sulla data privacy. Le eccezioni settoriali includono:

- **HIPAA** (Health Insurance Portability and Accountability Act): dati sanitari.
- **COPPA** (Children’s Online Privacy Protection Act): dati di minori sotto i 13 anni online.
- **FCRA** (Fair Credit Reporting Act): richieste di prestito e credito.
- **ECPA** (Electronic Communications Privacy Act, 1986): sicurezza informatica delle comunicazioni elettroniche.
- **Video Privacy Protection Act** (1988): protezione dei dati di noleggio video.
- **PATRIOT Act** (2001, post 9/11): consente sorveglianza governativa estesa.

Un’azienda che raccoglie dati (anche senza permesso esplicito) ha il diritto di usarli. Gli istituti finanziari possono ottenere informazioni sulla condizione finanziaria di una persona chiedendo report a terze parti.

1.6 Privacy nell'Unione Europea

L'UE protegge **pesantemente** la data privacy. Il fondamento giuridico è:

- **ECHR Art.8** (European Convention on Human Rights): prevede il diritto al rispetto della vita privata, familiare, del domicilio e della corrispondenza. La Corte Europea dei Diritti dell'Uomo ha dato a quest'articolo un'interpretazione molto ampia, includendo:
 - Raccolta di informazioni per il **censimento ufficiale**.
 - Registrazione di **impronte digitali e fotografie** in un registro di polizia.
 - Raccolta di **dati medici** o dettagli sulle spese personali.
 - Implementazione di un **sistema di identificazione personale**.

Ci sono state **due ere** della privacy europea:

1. **1995–2018**: Data Protection Directive (DPD) 95/46/EC.
2. **2018–presente**: General Data Protection Regulation (GDPR) (EU) 2016/679.

1.6.1 Data Protection Directive 95/46/EC

La DPD fu adottata nel 1995 dal parlamento europeo come tentativo di armonizzare la protezione dei dati nell'UE; doveva essere recepita dai singoli stati con leggi nazionali entro il 1998.

8 principi di base del DPD:

1. I dati personali devono essere processati a norma di legge e in maniera corretta.
2. I dati personali devono essere processati solo per scopi limitati.
3. I dati personali devono essere processati in modo adeguato, rilevante e non eccessivo.
4. I dati personali devono essere processati accuratamente.
5. I dati personali devono essere trattenuti solo per il tempo strettamente necessario.
6. I dati personali devono essere processati in accordo con i diritti del soggetto interessato.
7. I dati personali devono essere processati in modo sicuro.
8. I dati personali devono essere trasferiti solo a nazioni con una protezione adeguata.

Definizione: Dati Personali – DPD

“Any information relating to an identified or identifiable natural person (data subject); an identifiable person is one who can be identified, directly or indirectly, in particular by reference to an identification number or to one or more factors specific to his physical, physiological, mental, economic, cultural or social identity.”

Definizione: Trattamento dei Dati – DPD

“Any operation or set of operations which is performed upon personal data, whether or not by automatic means, such as collection, recording, organization, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, blocking, erasure or destruction.”
*Piccole modifiche nel GDPR: aggiunge **structuring** (strutturazione) e **restriction** (limitazione).*

Definizione: Controller e Processor – DPD/GDPR

- **Controller** (*Titolare del trattamento*): la persona fisica o giuridica, l'autorità pubblica, il servizio o qualsiasi altro organismo che, da solo o insieme ad altri, **determina le finalità e i mezzi del trattamento** dei dati personali. La responsabilità della compliance ricade sul controller.
- **Processor** (*Responsabile del trattamento*): la persona fisica o giuridica, l'autorità pubblica, il servizio o qualsiasi altro organismo che tratta dati personali **per conto del controller**.

Nessuna modifica significativa nel GDPR.

Tre principi fondamentali della DPD:

1. Trasparenza I dati possono essere processati solo se almeno una delle seguenti condizioni è vera:

- Il soggetto ha dato il proprio **consenso**.
- Il trattamento è necessario per l'**esecuzione di un contratto**.
- Il trattamento è necessario per **assolvere un obbligo legale**.
- Il trattamento è necessario per **proteggere gli interessi vitali** del soggetto.
- Il trattamento è necessario per un'**operazione di interesse pubblico**.
- Il trattamento è necessario per **scopi di interesse legittimato dal controllore**, eccetto quando tali interessi sono sovrascritti da quelli del soggetto.

Diritti del soggetto: **accesso** a tutti i dati; **rettifica, cancellazione o blocco** dei dati incompleti, inaccurati o non conformi.

2. Scopo Legittimo I dati personali possono essere processati solo per *scopi legittimi e specificati* e non possono essere processati ulteriormente in modo incompatibile con tali scopi.

3. Proporzionalità

- I dati devono essere accurati e, quando necessario, aggiornati.
- I dati non devono essere mantenuti in una forma che permette l'identificazione del soggetto per più tempo del necessario.
- Salvaguardie per dati conservati per fini storici, statistici o scientifici.
- Restrizioni aggiuntive per **dati sensibili**: credenze religiose, opinioni politiche, salute, orientamento sessuale, razza, appartenenza a organizzazioni.
- Il soggetto può sempre opporsi al processamento per fini di **direct marketing**.
- Nessuna decisione che produce effetti legali o significativi può essere basata **esclusivamente** su un trattamento automatizzato.
- Diritto di **ricorso** per decisioni automatizzate.

Autorità di Controllo (DPD) Ogni stato membro deve istituire un'**autorità di supervisione** che:

- Monitora la protezione dei dati nel proprio stato.
- Dà avvisi al governo riguardo alle misure amministrative e ai regolamenti.
- Avvia procedure legali quando il regolamento viene violato.

Il controllore deve notificare all'autorità di supervisione: nome e indirizzo, scopi del trattamento, categorie di dati soggetti, destinatari, trasferimenti a paesi terzi, misure di sicurezza. Tali informazioni sono tenute in un **registro pubblico**.

1.6.2 Privacy in Italia

La DPD 95/46/EC è stata implementata in Italia con il Decreto Legislativo n. 196/2003 (*Codice in materia di protezione dei dati personali*). L'autorità italiana è il **Garante per la protezione dei dati personali**, competente in materia di: video sorveglianza, dati biometrici, dati sanitari, notifiche di data breach, informazioni bancarie, e-health records, profili online, processamenti da parte di system administrators, marketing e profiling, pagamenti mobili, cookies.

1.6.3 General Data Protection Regulation (GDPR)

Definizione: GDPR

Il GDPR (Regolamento (EU) 2016/679) è un **regolamento** (non una direttiva) adottato il 27 aprile 2016, applicabile dal **25 maggio 2018** dopo un periodo transitorio di due anni. A differenza di una direttiva, non richiede l'adozione di leggi nazionali di recepimento. L'obiettivo è rafforzare e unificare la protezione dei dati per tutti gli individui nell'UE, e semplificare il quadro normativo per le imprese internazionali.

Definizione: 7 Principi GDPR – Art. 5

Il GDPR stabilisce all'Art. 5 i seguenti principi per il trattamento dei dati personali:

1. **Liceità, correttezza e trasparenza** (*Lawfulness, fairness and transparency*): il trattamento deve avere una base giuridica (consenso, contratto, obbligo legale, interesse vitale, interesse pubblico, o interesse legittimo del titolare) e deve essere trasparente verso l'interessato.
2. **Limitazione della finalità** (*Purpose limitation*): i dati devono essere raccolti per finalità specifiche, esplicite e legittime e non possono essere trattati in modo incompatibile con quelle finalità.
3. **Minimizzazione dei dati** (*Data minimisation*): i dati devono essere adeguati, pertinenti e **limitati a quanto necessario** rispetto alle finalità.
4. **Esattezza** (*Accuracy*): i dati devono essere esatti e, se necessario, aggiornati; i dati inesatti devono essere cancellati o rettificati senza indugio.
5. **Limitazione della conservazione** (*Storage limitation*): i dati devono essere conservati in una forma che consenta l'identificazione degli interessati per un periodo non superiore a quello necessario.
6. **Integrità e riservatezza** (*Integrity and confidentiality*): i dati devono essere trattati con misure di sicurezza adeguate a proteggere da trattamenti non autorizzati, perdita, distruzione o danni accidentali.

7. **Responsabilità del titolare** (*Accountability*): il titolare del trattamento è responsabile del rispetto di tutti i principi ed è in grado di **dimostrarlo**.

Nota: GDPR vs DPD – Principali Novità

Il GDPR introduce modifiche significative rispetto alla DPD 95/46/EC:

- **Ambito geografico ampliato**: si applica a qualsiasi organizzazione che tratta dati di residenti UE, anche se non ha sede in Europa (portata extraterritoriale).
- **Accountability**: il titolare deve dimostrare attivamente la conformità (non basta essere conformi, bisogna dimostrarlo).
- **Consenso più rigoroso**: deve essere libero, specifico, informato e inequivocabile; il silenzio o le caselle pre-spuntate non costituiscono consenso.
- **Nuovi diritti**: portabilità dei dati, diritto all'oblio rafforzato, diritto di opposizione al profiling.
- **Notifica data breach**: obbligatoria entro 72 ore (nella DPD non era previsto un termine esplicito).
- **Privacy by Design e by Default**: ora esplicito obbligo normativo.
- **DPO**: figura obbligatoria per PA e grandi trattatori.
- **DPIA**: obbligatoria per trattamenti ad alto rischio.
- **Sanzioni molto più pesanti**: fino al 4% del fatturato mondiale (DPD: sanzioni nazionali molto più basse).
- **Definizione di dati personali aggiornata**: include location data, online identifier, dati genetici.

Definizioni aggiornate nel GDPR rispetto alla Direttiva:

Definizione: Dati Personali – GDPR

“Any information relating to an identified or identifiable natural person (data subject); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, **location data**, an **online identifier** or to one or more factors specific to the physical, physiological, **genetic**, mental, economic, cultural or social identity of that natural person.”

Novità rispetto al DPD: aggiunti **location data**, **online identifier** e fattori **genetici**.

Definizione: Trattamento dei Dati – GDPR

Uguale al DPD, ma include anche **structuring** (strutturazione) e **restriction** (limitazione).

Definizione: Pseudonimizzazione – GDPR

“The processing of personal data in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information; such

additional information is kept separately and is subject to technical and organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person.”

Esempio: cifrare i dati localmente e mantenere le chiavi di decifratura separatamente dai dati cifrati.

Se i dati personali sono pseudonimizzati con politiche e misure adeguate, sono considerati **effettivamente anonimi e non soggetti ai controlli e alle sanzioni del GDPR**. Il GDPR non si applica ai dati anonimi, inclusi quelli per scopi statistici o di ricerca.

Definizione: Personal Data Breach – GDPR

“A breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data transmitted, stored or otherwise processed.”

Il controllore ha l'obbligo di notificare l'autorità di supervisione **senza ingiustificato ritardo** (entro **72 ore**) dalla scoperta del breach, a meno che sia improbabile che causi rischi ai diritti e alle libertà degli individui. **Gli interessati devono essere notificati** se viene determinato un impatto avverso. Il **processor deve notificare il controller** senza ingiustificato ritardo quando viene a conoscenza di un breach. La notifica agli interessati **non è richiesta** se il controller ha implementato misure tecniche e organizzative appropriate che rendano i dati personali **intellegibili solo agli autorizzati** (ad esempio, la **cifratura**).

Diritti degli interessati nel GDPR:

- Consenso **chiaro ed esplicito** al trattamento.
- Accesso **più facile** ai propri dati.
- Diritto alla **rettifica**, alla **cancellazione** e al **diritto all'oblio** (diritto di essere dimenticati).
- **Diritto di opposizione**, incluso all'uso per “profiling”.
- Diritto alla **portabilità dei dati** da un fornitore di servizi a un altro.

Privacy by Design e by Default (GDPR):

- La protezione dei dati deve essere **integrata nei processi di business** fin dall'inizio.
- Le impostazioni della privacy devono essere al **livello più alto per default**.
- Misure tecniche e procedurali devono garantire compliance **lungo tutto il ciclo di vita** del trattamento.
- I dati personali vanno trattati **solo quando strettamente necessario** per ogni scopo specifico.

Definizione: Privacy by Design – Ann Cavoukian, 2012

Un approccio all'ingegneria dei sistemi che tiene in considerazione la privacy durante tutto il ciclo di vita. Si basa su **7 principi fondamentali**:

1. **Proattività, non reattività; prevenzione, non rimedio** – anticipare e prevenire i rischi per la privacy.

2. **Privacy come impostazione di Default** – il massimo livello di privacy senza che l'utente faccia nulla.
3. **Privacy integrata nel Design** – incorporata nell'architettura del sistema, non aggiunta a posteriori.
4. **Completamente funzionale – positive-sum, non zero-sum** – privacy e funzionalità non si escludono; entrambe possono coesistere.
5. **End-to-end security – protezione dell'intero ciclo di vita** – sicurezza per tutta la durata del trattamento.
6. **Visibilità e trasparenza – keep it open** – tutte le attività sono visibili e verificabili.
7. **Rispetto per la privacy degli utenti – keep it user-centric** – l'utente al centro; la sua privacy è prioritaria.

Responsabilità e Accountability (GDPR):

- Il **titolare del trattamento** (data controller) deve dimostrare compliance con il GDPR implementando misure di Privacy by Design e by Default.
- Gli utenti devono essere chiaramente informati: estensione della raccolta dati, base giuridica del trattamento, durata della conservazione, trasferimenti a terzi o fuori dall'UE, uso di decision-making automatizzato.
- Devono essere forniti i contatti del **Data Protection Officer (DPO)**, figura prevista dal GDPR con competenze esperte in data protection law e pratiche. Il DPO assiste il controller/processor nel monitorare la compliance interna; deve essere competente anche nella gestione dei processi IT, nella **data security** (inclusi attacchi informatici) e nelle questioni di **business continuity** relative alla detenzione e al trattamento di dati personali e sensibili. La nomina del DPO è **obbligatoria** per autorità pubbliche e imprese la cui attività principale consiste nel trattamento regolare o sistematico di dati personali su larga scala.
- Il **Data Protection Impact Assessment (DPIA)** deve essere condotto quando il trattamento presenta **rischi specifici** per i diritti e le libertà degli interessati. Richiede valutazione e mitigazione del rischio; per rischi **elevati** è necessaria la **previa approvazione** dell'autorità nazionale di protezione dei dati (DPA).
- Il titolare deve mantenere **registri delle attività di trattamento** che includano le finalità, le categorie di dati coinvolte e i **termini di conservazione** previsti. Tali registri devono essere messi a disposizione dell'autorità di supervisione su richiesta.

Sanzioni GDPR:

- Prima violazione non intenzionale: **avviso scritto**.
- **Audit periodici** di protezione dei dati come misura correttiva.
- Violazione di obblighi: multa fino a **10 milioni di euro** o **2% del fatturato mondiale** annuo dell'esercizio precedente (la cifra maggiore).
- Violazione grave dei principi: multa fino a **20 milioni di euro** o **4% del fatturato mondiale** annuo dell'esercizio precedente (la cifra maggiore).

1.7 Accordi Transnazionali EU–USA

1. **Safe Harbor** (sviluppato 1998–2000, in vigore fino al 2015): sviluppato per impedire la divulgazione accidentale o la perdita di informazioni personali di cittadini UE verso organizzazioni negli USA. Le aziende USA potevano auto-certificarsi aderendo a **7 principi**:
 - (a) **Notice**: gli individui devono essere informati che i loro dati vengono raccolti e di come verranno usati.
 - (b) **Choice**: gli individui devono poter **opt-out** dalla raccolta e dal trasferimento dei dati a terze parti.
 - (c) **Onward Transfer**: i trasferimenti a terze parti possono avvenire solo verso organizzazioni che seguono principi adeguati di protezione dei dati.
 - (d) **Security**: devono essere fatti sforzi ragionevoli per prevenire la perdita di dati raccolti.
 - (e) **Data Integrity**: i dati devono essere **rilevanti e affidabili** per lo scopo per cui sono stati raccolti.
 - (f) **Access**: gli individui devono poter **accedere, correggere e cancellare** le informazioni detenute su di loro.
 - (g) **Enforcement**: devono esistere **meccanismi efficaci** per far rispettare queste regole.

La Commissione Europea ha riconosciuto nel 2000 che i principi USA erano conformi alla Direttiva UE (*Safe Harbour Decision*). Nel 2015, a seguito di un reclamo di un cliente il cui dato Facebook era insufficientemente protetto, la CJEU ha dichiarato invalida la Safe Harbour Decision (**caso Schrems vs. Facebook**), aprendo trattative per un nuovo accordo.

2. **EU-US Privacy Shield** (adottato 12 luglio 2016, in vigore fino al luglio 2020): sostituì Safe Harbor; framework per gli scambi transatlantici di dati personali per scopi commerciali. Consentiva alle aziende USA di ricevere dati da entità UE in conformità alle leggi europee. Il Presidente USA Donald Trump firmò un Executive Order (“Enhancing Public Safety”) che stabiliva che le protezioni sulla privacy USA **non si estendevano ai non-cittadini o residenti USA**. Nel **luglio 2020**, la CJEU ha dichiarato invalido il Privacy Shield perché non garantiva adeguata protezione ai cittadini UE contro lo **spionaggio governativo USA**; i trasferimenti effettuati su questa base sono stati dichiarati **illegali**.
3. **EU-US Data Privacy Framework** (2023–presente): il quadro attualmente in vigore.

1.8 AI Act (Agosto 2024)

Definizione: AI Act

La legge sull’IA (in vigore dal 1° agosto 2024 nell’UE) mira a garantire che i sistemi di IA siano sicuri, trasparenti e rispettosi dei diritti fondamentali. Classifica i sistemi di IA in 4 livelli di rischio:

1. **Rischio inaccettabile – Vietati** (Art. 5): sistemi che rappresentano una chiara minaccia alla sicurezza o ai diritti fondamentali: manipolazione subliminale del comportamento, sfruttamento di vulnerabilità di gruppi specifici, social scoring governativo, riconoscimento facciale di massa, AI con dark-pattern.
2. **Alto rischio – Conformity Assessment** (Art. 6 e ss.): sistemi in aree critiche (sanità, istruzione, occupazione, giustizia, immigrazione, forze dell’ordine, infrastrut-

ture essenziali). Soggetti a: valutazione rigorosa dei rischi, governance dei dati, supervisione umana, monitoraggio continuo.

3. **Rischio limitato – Trasparenza** (Art. 52): sistemi come chatbot, deepfake, sistemi di riconoscimento delle emozioni. Obblighi di trasparenza: i provider e deployer devono informare gli utenti che stanno interagendo con un sistema IA.
4. **Rischio minimo – Codice di condotta** (Art. 69): la maggior parte dei sistemi IA (videogiochi, filtri antispam). Essenzialmente non regolamentati, per favorire l'innovazione.

AI Act – General Purpose AI (GPAI): tutti i provider di modelli GPAI devono: fornire documentazione tecnica e istruzioni d'uso; rispettare la Direttiva Copyright UE; pubblicare un sommario dei dati di training; condurre valutazioni e test avversariali per modelli con rischi sistemici; garantire robuste protezioni di cybersecurity.

Obblighi per Provider e Deployer di AI ad alto rischio:

- **Provider (sviluppatori):** devono implementare un sistema di gestione del rischio, garantire dataset di alta qualità, mantenere documentazione tecnica dettagliata, progettare sistemi con adeguati livelli di accuratezza, robustezza e cybersecurity.
- **Deployer (utenti):** devono usare i sistemi come previsto, monitorarne le prestazioni e garantire la **supervisione umana** per prevenire e mitigare i rischi.

AI Act – Governance e Enforcement: l'AI Act istituisce il **European Artificial Intelligence Board**, che supervisiona l'implementazione e garantisce un'applicazione coerente negli Stati Membri. Le autorità nazionali competenti supervisionano e fanno rispettare la compliance nelle rispettive giurisdizioni.

1.9 Digital Services Act (DSA, 2022)

Il DSA è un regolamento UE volto a creare uno **spazio digitale più sicuro**, dove i diritti fondamentali degli utenti siano protetti e venga stabilito un livello equo per le imprese. Il principio chiave è: *“ciò che è illegale offline deve essere illegale anche online.”*

Il codice contiene **44 impegni e 128 misure** che coprono quattro aree principali:

- **Demonetizzazione:** riduzione degli incentivi finanziari per chi diffonde disinformazione.
- **Trasparenza della pubblicità politica:** etichettatura più efficiente per permettere agli utenti di riconoscere la pubblicità politica.
- **Integrità dei servizi:** riduzione di account fake, amplificazione tramite bot, deepfake malevoli e altri comportamenti manipolatori per diffondere disinformazione.
- **Fact-checking:** strumenti per aiutare gli utenti a identificare la disinformazione; accesso più ampio ai dati; copertura fact-checking in tutta l'UE.

Il DSA **non richiede** la rimozione di contenuti legali ma dannosi (come la disinformazione in senso lato), ma si concentra sui contenuti **illegali** (incitamento all'odio, merci contraffatte, pornografia infantile). I meccanismi di segnalazione (**“Notice and Action”**) impongono alle piattaforme di fornire strumenti facili per segnalare contenuti illegali.

Trasparenza: le piattaforme devono spiegare agli utenti perché un contenuto è stato rimosso o limitato e offrire la possibilità di appello. Include: trasparenza sugli **algoritmi di raccomandazione**, **trasparenza pubblicitaria** e **divieto di profilazione**: la pubblicità mirata basata su dati sensibili (orientamento sessuale, religione, etnia) o rivolta a minori è **vietata**.

Protezione dei minori: il DSA impone misure rafforzate per proteggere i minori online, garantendo alti livelli di privacy, sicurezza e riduzione dell'esposizione a contenuti inappropriati.

Sanzioni: ogni Stato Membro nomina un **Coordinatore Nazionale** per supervisionare la compliance. In caso di inadempienza, la Commissione Europea può imporre sanzioni fino al **6% del fatturato globale annuo** delle piattaforme. Il DSA, insieme al **Digital Markets Act (DMA)**, costituisce la pietra angolare della strategia europea per un mercato digitale unico più sicuro e giusto.

1.10 Data Act (settembre 2025)

Il **EU Data Act**, in vigore da settembre 2025, garantisce a utenti (individui e imprese) un **maggiore controllo sui dati generati da dispositivi connessi (IoT)** e servizi. I produttori sono obbligati a rendere questi dati accessibili agli utenti, abilitando **portabilità dei dati**, cambio di cloud provider e protezione da termini contrattuali iniqui.

Aspetti chiave:

- **User Data Access & Control:** gli utenti possono accedere e condividere con terze parti i dati generati da prodotti (smart home, auto, macchinari industriali).
- **Fairness in Data Sharing:** restringe i produttori dall'imporre termini contrattuali iniqui che blocchino gli utenti in servizi proprietari.
- **Cloud Switching:** facilita lo spostamento di dati e applicazioni tra diversi cloud provider senza costi aggiuntivi.
- **Public Sector Access:** gli enti pubblici possono richiedere dati da aziende private in situazioni eccezionali (emergenze pubbliche, compiti specifici).
- **International Transfers:** introduce regole per prevenire l'accesso illecito di governi di paesi terzi ai dati non personali.

1.11 Digital Omnibus (proposta novembre 2025)

Il **Digital Omnibus** è un pacchetto di proposte presentato dalla Commissione Europea il 19 novembre 2025, volto a **semplificare il quadro normativo digitale** dell'UE (GDPR, AI Act, NIS2 – sicurezza delle reti in 18 settori critici: energia, trasporti, sanità, finanza, acqua, infrastrutture digitali, servizi postali, pubblica amministrazione, aerospazio). Obiettivo primario: **ridurre la burocrazia** per le imprese, specialmente le PMI, mantenendo le protezioni dei cittadini.

Le proposte includono:

- Chiarimento dell'applicazione del GDPR riguardo a **dati personali e interesse legittimo**.
- Semplificazione delle **normative sui cookie**.
- Rendere le regole sull'IA più favorevoli all'innovazione con meccanismi come il **stop-the-clock**.
- Introduzione di un **Single-Entry Point** per la segnalazione di incidenti di cybersecurity.
- Estensione del periodo di notifica di data breach a **90 ore**.

Nota: Omnibus – Rilassamento della definizione di dato personale

Una proposta chiave riguarda la ridefinizione di “dato personale”: per determinare se una persona fisica è identificabile, è appropriato considerare **tutti i mezzi che ragionevol-**

mente potrebbero essere usati per identificarla. L'esistenza di informazioni aggiuntive che abilitano l'identificazione **non implica che i dati pseudonimizzati siano dati personali per tutti e in ogni caso**. In particolare, le informazioni **non devono essere considerate dati personali per un'entità se quell'entità non dispone dei mezzi per identificare la persona fisica**. Questo rappresenta una *rilassazione* rispetto alla posizione GDPR corrente, potenzialmente favorendo la ricerca e riducendo i costi di compliance.

Esempio collegato: il trattamento di dati personali necessario a **identificare e eliminare distorsioni nei dataset** e proteggere i soggetti dalla discriminazione persegue un **interesse legittimo** ai sensi dell'Art. 6(1)(f) del GDPR, senza necessità di consenso esplicito, purché gli interessi fondamentali dell'interessato non prevalgano.

Esempio AI/ML (pag. 12 Omnibus): lo sviluppo di certi sistemi IA può richiedere la raccolta di grandi quantità di dati, incluse **categorie speciali** (dati sensibili). Per non ostacolare lo sviluppo dell'IA, l'Omnibus propone di consentire un'**eccezione al divieto di trattamento** di dati sensibili, a condizione che il controller abbia adottato misure tecniche e organizzative adeguate per **prevenire il trattamento**, abbia adottato misure per l'intero ciclo di vita e **rimuova effettivamente** tali dati una volta identificati. Se la rimozione richiedesse uno sforzo sproporzionato (ad esempio, richiederebbe la re-ingegnerizzazione del sistema), il controller deve **proteggere efficacemente** tali dati in modo che non vengano usati per generare output, divulgati o resi disponibili a terzi.

2 Big Data e Minacce alla Privacy

2.1 Il Problema dei Big Data

Definizione: Big Data

Il termine Big Data si riferisce all'acquisizione e all'analisi di enormi collezioni di informazioni, talmente grandi che fino a poco tempo fa la tecnologia per analizzarle non esisteva.

Il fenomeno della **datafication**: tutto viene convertito in dati (carte di credito, registri di chiamate, dati sanitari, email, social, DNA, etc.). Questo crea un trade-off: più privacy $\Leftrightarrow$ meno comodità.

Definizione: Big Data – caratteristiche chiave

I Big Data sono caratterizzati da:

- Grandi quantità di dati *non strutturati* e “disordinati” (messy data).
- Evidenziano pattern altrimenti non rilevabili.
- Raccolta indiscriminata: i dati vengono collezionati senza un obiettivo preciso.
- Conservazione indefinita per utilizzi futuri imprevedibili.

Legge delle Conseguenze Inattese: tecnologie create per uno scopo vengono poi usate per scopi completamente diversi, con implicazioni per la privacy impreviste al momento della creazione.

- Il **Social Security Number (SSN)** fu creato per la previdenza sociale, ma ora è usato come identificatore universale (studente, banca, medico, etc.).

- I **telefoni cellulari** furono pensati per le comunicazioni vocali, ora sono usati per pagamenti, tracciamento GPS, autenticazione.
- I **laser** furono inventati per la fisica, ora leggono DVD e codici a barre.
- Il **DNA**: “Per cosa verrà usato il DNA?” – oggi è usato per prova forense, diagnosi genetica, genealogia, ma anche per discriminazione assicurativa.

2.2 Deanonimizzazione

La principale minaccia dei Big Data è la possibilità di **deanonimizzare** dati apparentemente anonimi combinandoli con altri dataset pubblicamente disponibili.

Esempio: Netflix Prize (2006)

Netflix pubblica un dataset anonimizzato con 100 milioni di valutazioni di film (da circa 500.000 utenti) per una data challenge. Narayanan e Shmatikov mostrano che incrociando il dataset con IMDb (ratings pubblici), conoscendo solo 6-8 valutazioni di film con date approssimate, è possibile re-identificare gli utenti con probabilità del 90%. Netflix cancellò la seconda fase della sfida a causa di questo rischio. **Lezione**: non è sempre possibile anonimizzare i dati semplicemente rimuovendo gli identificatori; gli esseri umani sono prevedibili e i pattern comportamentali permettono la re-identificazione.

Esempio: AOL Search Release (2006)

AOL pubblica 650.000 query di ricerca di circa 650.000 utenti su un periodo di 3 mesi (agosto 2006), “anonimizzate” sostituendo i nomi con ID numerici. Il dataset viene rimosso dopo soli 3 giorni ma era già stato scaricato. Il New York Times riesce a identificare individui specifici: ad esempio, l’utente #4417749 viene identificato come **Thelma Arnold**, una vedova 62enne di Lilburn, Georgia, con 3 cani – le sue query contenevano “landscapers in Lilburn, Ga”, “homes sold in shadow lake subdivision gwinnett county georgia”, etc.

Dataset	Dettagli	Risultato
AOL queries	650K utenti, 3 mesi	Re-ID da NY Times
Chicago homicide DB	database criminali	re-identificati
Netflix Prize	500K utenti, 100M valutazioni	Re-ID con IMDb
MA medical records	Sweeney vs. Gov. Weld	ZIP+sex+DoB
Southern Illinoisan	vs. Dept. of Public Health	re-ID pazienti
Canadian Adverse Events	database medici	re-ID pazienti

Tabella 1: Esempi di tentativi di re-identificazione su dataset “anonimi”

Cause principali dei data breach (IBM/Ponemon 2019):

- Credenziali compromesse: 19%
- Cloud configurato in modo errato: 19%
- Vulnerabilità software: 16%

Costo medio in Italia (IBM/Ponemon 2019): 3,1 milioni di euro per violazione. **Costo per i cittadini**: tra 1.000 e 3.000 USD/anno in danni da furto di identità e uso improprio dei dati personali.

Caso INPS (marzo–aprile 2020): durante la pandemia, il portale INPS per richiedere il bonus di 600 euro rese visibili i dati di altri utenti a causa di un data breach; il sito fu temporaneamente chiuso.

Esempio: Cambridge Analytica / Facebook (2018)

Cambridge Analytica raccoglie dati di circa 87 milioni di utenti Facebook attraverso un'app-quiz (thisisyourdigitallife) che, con il consenso di circa 270.000 utenti, accedeva anche ai dati degli amici. Questi dati vengono usati per costruire profili psicologici e mirare messaggi politici personalizzati, con l'obiettivo di influenzare le elezioni presidenziali USA del 2016 e il referendum Brexit. Dimostrazione che i dati raccolti per una finalità vengono usati per un'altra (violazione del principio di scopo legittimo).

Esempio: Studio PNAS 2013 – Facebook Likes

Kosinski et al. mostrano che analizzando i “Like” su Facebook con SVD (Singular Value Decomposition) + regressione logistica, si può predire con alta accuratezza: orientamento sessuale, etnia, opinioni politiche, religione, stato relazionale, uso di droghe, e persino la personalità secondo il modello Big Five. I Like apparentemente innocui (musica, film) possono rivelare informazioni altamente sensibili (**proxy attributes**).

Valori AUC (Area Under the Curve) ottenuti:

Attributo predetto	AUC
Genere	0.93
Omosessualità maschile	0.88
Caucasico vs Afroamericano	0.95
Democratico vs Repubblicano	0.85
Cristiano vs Musulmano	0.82
Omosessualità femminile	0.75
Single vs In relazione	0.67
Genitori insieme a 21 anni	0.60
Fumatore	0.73
Consumo di alcol	0.70
Uso di droghe	0.65

Esempio: Sweeney – 87% della Popolazione USA

Latanya Sweeney (2001) dimostra che l'**87% della popolazione USA** è unicamente identificabile dalla combinazione di soli tre attributi: {ZIP code, sesso, data di nascita completa}. Questi attributi sembrano innocui individualmente ma combinati formano un quasi-identificatore univoco.

3 Sistemi Informativi e Privacy

Definizione: Sistema Informativo

Un **sistema informativo** è un sistema formale, sociotecnico e organizzativo progettato per **raccogliere**, **elaborare**, **memorizzare** e **distribuire** informazioni usate da un'organizzazione.

Un **computer information system** è un insieme di componenti software e hardware che

lavorano insieme per: raccogliere/acquisire, memorizzare, elaborare e distribuire **informazioni** con l'obiettivo di supportare le **attività** (automazione) e le **decisioni** (analisi, controllo, coordinamento, reporting) dell'organizzazione.

I sistemi informativi gestiscono dati di diversi tipi: dati di identificazione personale, contenuti generati dagli utenti, email, dati transazionali, log di processo, dati applicativi, ecc. Questi dati appartengono a dipendenti, clienti/utenti, fornitori, ecc.

Per proteggere la privacy nei sistemi informativi si agisce a diversi livelli: formazione di dipendenti e manager, rafforzamento della cybersecurity, protezione delle infrastrutture di rete e server, restrizione dell'accesso fisico alle aree sensibili, utilizzo di VPN per il lavoro remoto, aggiornamento del software.

Definizione: IS e GDPR – Requisiti

Un sistema informativo conforme al GDPR deve garantire:

- **Autorizzazione basata su attributi:** meccanismo di autorizzazione dichiarativo e completamente tracciabile per l'accesso a tutti i dati, in circostanze predefinite.
- **Anonimizzazione/Pseudonimizzazione:** meccanismi sicuri per la pseudonimizzazione o anonimizzazione delle informazioni.
- **Tracciabilità:** registro di chi ha creato, modificato o cancellato informazioni, quando e per quale scopo.
- **Cancellazione dei dati:** meccanismi sicuri per garantire il “diritto all'oblio” senza compromettere l'affidabilità del sistema.

Esempio: IS e GDPR – Alice chiede un mutuo

Alice richiede un mutuo e si rivolge a un consulente indipendente. Il consulente raccoglie informazioni personali di Alice, richiede preventivi a banche. Domande rilevanti: quali parti hanno memorizzato dati personali di Alice? Come può Alice sapere dove e da chi sono conservati? Tutte le parti rispettano il GDPR? Come può Alice far cancellare i suoi dati?

3.1 Controllo degli Accessi

Definizione: Access Control

L'**access control** consiste nel limitare l'accesso alle risorse informatiche, specialmente in ambienti multi-utente con condivisione di dati. Esempio: un paziente può richiedere che le sue cartelle cliniche elettroniche siano accessibili solo a un medico registrato in una specifica unità di uno specifico ospedale; ma in emergenza, qualsiasi medico deve poter accedere. Essere “un medico” non è sufficiente per garantire l'accesso in condizioni normali.

3.1.1 RBAC – Role Based Access Control

Definizione: RBAC

Formalizzato da NIST nel 1992. Adatto per aziende con oltre 500 dipendenti. Gestisce l'accesso in base al *ruolo* invece che all'identità individuale. Il ruolo fornisce un livello extra di astrazione (collezione di permessi/diritti). Ogni ruolo può essere assegnato a uno o centinaia di utenti, semplificando la gestione.

Funzionamento: gli amministratori assegnano permessi a ogni ruolo; i ruoli vengono assegnati agli utenti; gli utenti possono avere più ruoli (ognuno con diversi diritti di accesso); gli amministratori aggiornano l'accesso semplicemente assegnando/rimuovendo utenti dai ruoli appropriati.

Limiti di RBAC: fornisce configurazioni di accesso grossolane (*coarse-grained*), predefinite e statiche; non fornisce un meccanismo flessibile per esprimere i requisiti di clienti/utenti e istituzioni; non cattura lo *scopo* per cui i dati vengono rilasciati. Oggi, definire le policy di autorizzazione basandosi solo sul ruolo non è sufficiente: serve anche il *contesto* (utente giusto, al momento giusto, nel luogo giusto, nel rispetto della compliance).

3.1.2 ABAC – Attribute Based Access Control

Definizione: ABAC

Evoluzione di RBAC. Le decisioni autorizzative possono basarsi su: ruolo, persone/oggetti collegati all'utente, necessità dell'accesso, luogo, tempo, modalità di accesso.

Caratteristiche: approccio *policy driven*; usa attributi di **soggetto** (subject), **oggetto** (resource) e **ambiente** (environment) invece dei soli ruoli; rimuove la necessità di registrazione esplicita nel sistema. Le policy espresse con attributi permettono autorizzazioni più ricche e contestuali.

Struttura di una policy ABAC: ogni policy si legge come una frase con 4 componenti grammaticali:

- un **soggetto** (chi richiede l'accesso; attributi: ruoli, gruppi, dipartimento, livello manageriale, etc.)
- un'azione (cosa vuole fare: “read”, “write”; in online banking: tipo=deposito, importo=1000)
- una **risorsa** (a cosa accede; attributi: classificazione, proprietario, etc.)
- l'**ambiente** (contesto: ora, luogo, dispositivo, etc.)

Esempio: Policy ABAC in linguaggio naturale

*“I medici possono visualizzare le cartelle cliniche di **qualsiasi** paziente nel loro **reparto** e aggiornare **qualsiasi** cartella che sia loro direttamente assegnata, durante l'**orario di lavoro** e da un **dispositivo approvato**.”*

Aggiungendo contesto, l'ABAC può anche esprimere vincoli come: un utente può creare ordini di acquisto e approvarli, ma non può approvare i propri ordini (separazione dei compiti).

Authorization Engine (componenti):

- **PEP** (Policy Enforcement Point): applica le decisioni di accesso.
- **PDP** (Policy Decision Point): valuta le policy e decide se permettere o negare.

- **PAP** (Policy Administration Point): gestisce le policy.
- **PIP** (Policy Information Point): recupera attributi aggiuntivi.

Le policy sono espresse in **XACML** (eXtensible Access Control Markup Language): standard XML per ABAC. Algoritmi di combinazione: *permit-overrides* (un Permit è sufficiente) e *deny-overrides* (un Deny prevale).

Esempio: XACML – Healthcare Data Store

Un data store riceve dati clinici da vari fornitori sanitari. I dati devono essere processati secondo le istruzioni del paziente e le regole legali prima di essere distribuiti a ricercatori autorizzati. Le policy coinvolgono quattro soggetti: *Institute 1*, *Institute 2*, *Patient 1* e *Patient 2*.

Policy di Institute 1: consente il rilascio di dati a livello di paziente a **ricercatori** come dataset limitati, purché i richiedenti possano attestare la **conformità GDPR**.

Frammento XACML (Institute 1):

```
<PolicySet policy-combining-algorithm="permit-overrides">
  <Policy rule-combining-algorithm="deny-overrides">
    <Rule RuleId="I1R1" Effect="Permit">
      <Condition>
        <!-- Researcher con GDPR-compliance -->
        :access-subject :Role :Researcher
        :access-subject :GDPRComp :Yes
      </Condition>
    </Rule>
  </Policy>
</PolicySet>
```

Policy di Institute 2: consente solo il rilascio di **statistiche aggregate** (media, conteggio); **nessun dato individuale**. Non è richiesta la GDPR compliance ai riceventi, ma le statistiche basate su meno di 10 pazienti non sono ammesse:

```
<Rule RuleId="I2R1" Effect="Permit">
  <Condition>
    <!-- AggregateHealthData e PatientCount > 10 -->
    :resource :Type :AggregateHealthData
    :resource :PatientCount > 10
  </Condition>
</Rule>
```

Policy di Patient 1: ex-tossicodipendente, non vuole condividere informazioni sul suo passato di uso di droghe.

```
<Rule RuleId="P1R1" Effect="Permit">
  <Condition>
    <!-- Nega contenuto Drug-usage per Patient1 -->
    :resource :Resource-owner :Patient1
    string-not-equal(:resource :Content :Drug-usage)
  </Condition>
</Rule>
```

Policy di Patient 2: politico molto noto che approva solo il rilascio di dati di trattamento/visita con granularità a livello annuale. La regola P2R2 introduce un'**obligation** di riscrivere la data (`rewriteDate`).

Richiesta di accesso di esempio (XACML Request REQ1): la ricercatrice Carol (:Role :Researcher, :GDPRComp :Yes) richiede il rilascio di dati sanitari (HealthData) relativi a Drug-usage, Symptoms, Disease, Duration e Date; filtro: Disease=HepC, Duration=Monthly, nell'arco del primo anno (`resource.Date+365 > CurrentDate`). Scopo: :Purpose-id :DrugEffect.

Elaborazione della richiesta (Policy Evaluation):

- **PolicySetInstitute1:** il Target corrisponde (Researcher, HealthData, Release). La Policy1 si applica; la regola I1R1 verifica `GDPRComp=Yes` → soddisfatta → **Permit**. Il ricercatore ottiene accesso ai dati di Institute 1.
- **PolicySetInstitute2:** il Target corrisponde, si applica Policy2. Il Target di Policy2 richiede `AggregateHealthData`, ma la richiesta è per `HealthData` individuale → Target non soddisfatto → **inapplicabile**. Nessuna policy di Institute 2 si applica.
- **PolicySetPatient1:** il Target corrisponde, si applica PP1. La regola P1R1 verifica che il contenuto richiesto non sia `Drug-usage` (`string-not-equal`), ma la richiesta include Drug-usage → condizione non soddisfatta → nessuna policy di Patient 1 soddisfa la richiesta. L'accesso ai dati di drug-usage è **negato**.
- **PolicySetPatient2:** il Target corrisponde, si applica PP2. P2R1 e P2R2 verificano che `Resource-owner=Patient2` e `Duration=Yearly` → entrambe Permit. P2R3 è la regola di default → Deny. Conflitto P2R2/P2R3, ma l'algoritmo di PP2 è **permit-overrides** → **Permit**. *Obligation:* riscrivere le date con granularità annuale (`rewriteDate`).

Risultato finale: Carol ottiene accesso ai record di Patient 2 presenti in Institute 1, con le date riscritte a livello annuale. I dati di drug-usage non sono accessibili (bloccati dalla policy di Patient 1).

3.2 Pseudoanonimizzazione con Crittografia

Definizione: Pseudoanonimizzazione

Una procedura di data management e de-identificazione per cui informazioni identificabili in un record sono rimpiazzate da uno o più identificatori artificiali (pseudonimi). Un singolo pseudonimo per ogni campo sostituito rende il record meno identificabile pur restando adatto ad analisi e processing.

I dati pseudonimizzati **possono essere ripristinati** allo stato originale con l'aggiunta di informazioni aggiuntive (es. la tavola di corrispondenza pseudonimo↔identità reale), permettendo la re-identificazione.

I dati **anonimizzati** non possono *mai* essere ripristinati al loro stato originale: l'anonimizzazione è irreversibile.

Definizione: Crittografia su Colonne

Tecnica per proteggere dati sensibili nei database senza rivelare la chiave all'engine del database. Separa chi possiede i dati da chi li gestisce.

- **Column encryption keys:** per cifrare il dato.

- **Column master keys:** per cifrare le column encryption keys (conservate in repository esterno).

Il DBMS conserva solo i valori cifrati delle column encryption keys e la posizione delle column master keys (mai in chiaro). La configurazione di cifratura per ogni colonna è nel database metadata.

Tipi di cifratura:

- **Deterministica:** genera sempre lo stesso valore cifrato per lo stesso testo in chiaro ⇒ supporta point lookup, equality join, grouping, indexing. Svantaggio: un attaccante può inferire informazioni esaminando pattern (es. se i possibili valori sono pochi come True/False).
- **Randomizzata:** cifra i dati in modo meno prevedibile ⇒ più sicura, ma impedisce ricerche, grouping, indexing e join su colonne cifrate.

RSA (Rivest-Shamir-Adleman): uno dei più antichi sistemi crittografici a chiave pubblica. L'utente pubblica una chiave pubblica basata su due grandi numeri primi (tenuti segreti) e un valore ausiliario. Chiunque può cifrare con la chiave pubblica; solo il possessore della chiave privata può decifrare. **Padding:** aggiunta di dati all'inizio, alla fine o in mezzo al messaggio prima della cifratura, per oscurare pattern prevedibili (es. molti messaggi terminano nello stesso modo). **OAEP** (Optimal Asymmetric Encryption Padding) è uno schema di padding spesso usato con RSA.

TDE (Transparent Data Encryption – Oracle): usa una singola chiave di cifratura per tutte le colonne cifrate. Le chiavi delle colonne sono cifrate con la **master key** del server e conservate in una tabella del dizionario del database. Nessuna chiave è conservata in chiaro. La master key è conservata in un **modulo di sicurezza esterno** (Oracle Wallet), accessibile solo all'amministratore della sicurezza; il Wallet genera anche le chiavi e gestisce cifratura/decifratura. Questo separa le responsabilità tra amministratori del database e amministratori della sicurezza: **nessun singolo amministratore ha accesso completo a tutti i dati.**

Salt: stringa casuale aggiunta ai dati *prima* della cifratura, che fa apparire lo stesso testo in chiaro diverso una volta cifrato. Rimuove la possibilità di attacchi per pattern-matching sul testo cifrato. **Attenzione:** se si indicizza una colonna cifrata, *occorre disabilitare il Salt* (ENCRYPT NO SALT), perché valori identici devono produrre lo stesso testo cifrato per consentire ricerche.

Esempio: Always Encrypted – Microsoft SQL Server

```
CREATE COLUMN MASTER KEY MyCMK
WITH (KEY_STORE_PROVIDER_NAME = 'MSSQL_CERTIFICATE_STORE',
      KEY_PATH = 'path');

CREATE COLUMN ENCRYPTION KEY MyCEK
WITH VALUES (COLUMN_MASTER_KEY = MyCMK,
             ALGORITHM = 'RSA_OAEP',
             ENCRYPTED_VALUE = encryptedkeyvalue);

CREATE TABLE Customers (
  CustName varchar(60)
  ENCRYPTED WITH (COLUMN_ENCRYPTION_KEY = MyCEK,
                ENCRYPTION_TYPE = RANDOMIZED,
```

```

        ALGORITHM = 'AEAD_AES_256_CBC_HMAC_SHA_256'),
    SSN varchar(11)
        ENCRYPTED WITH (COLUMN_ENCRYPTION_KEY = MyCEK,
            ENCRYPTION_TYPE = DETERMINISTIC,
            ALGORITHM = 'AEAD_AES_256_CBC_HMAC_SHA_256'),
    Age int NULL
);

```

CustName usa cifratura **randomizzata** (nessuna ricerca); SSN usa cifratura **deterministica** (permette ricerche per uguaglianza). La Column Master Key è protetta da RSA-OAEP e conservata in un key store esterno.

3.3 Auditing

Definizione: Auditing

Processo di esame e validazione di documenti, dati, processi, procedure e sistemi. Assicura che il sistema funzioni e sia conforme a policy, regolamenti e leggi. Viene eseguito dopo che il prodotto è stato messo in produzione.

Terminologia:

- **Audit log:** documento che contiene in ordine cronologico tutte le attività oggetto di audit.
- **Auditor:** persona autorizzata a effettuare un audit.
- **Audit procedure:** insieme di istruzioni per il processo di auditing.
- **Audit report:** documento che contiene i risultati dell'audit.
- **Audit trail:** registro cronologico di modifiche a documenti, dati, attività di sistema o eventi operativi.
- **Data audit:** registro cronologico delle modifiche ai dati, conservato in log file o tabella di database.
- **Database auditing:** registro cronologico delle attività sul database.

Obiettivi dell'audit: regole di business, controlli di sistema, regolamenti governativi, policy di sicurezza.

Obiettivi specifici del database auditing: integrità dei dati, utenti e ruoli delle applicazioni, riservatezza dei dati, controllo degli accessi, modifiche ai dati, modifiche alla struttura dati, disponibilità del database o dell'applicazione, change control, report di auditing.

Tipi di audit:

- **Internal auditing:** esame condotto da membri dello staff dell'organizzazione soggetta ad audit.
- **External auditing:** esame condotto da una terza parte indipendente.

Attività di auditing: identificare problemi di sicurezza; stabilire piani, policy e procedure; organizzare e condurre audit interni; verificare requisiti contrattuali; fare da tramite tra azienda e team di audit esterno; fornire consulenza al Dipartimento Legale.

Processo di auditing (tre fasi): Understand objectives → Review, verify and validate → Report and document.

Auditing models (informazioni registrate per ogni azione): stato dell'oggetto *prima* dell'azione; descrizione dell'azione eseguita; nome dell'utente che ha eseguito l'azione.

Modello 1 – Audit per entità e azione: registra entità auditate nel repository; traccia cronologicamente le attività.

- Entità: utente, tabella o colonna.
- Attività: transazioni DML (update, insert, delete) o logon/logoff.
- Stato dell'entità: active, deleted, inactive.

Modello 2 – Audit per variazione di colonna: registra solo le modifiche ai valori di colonna; prevede un meccanismo di purging e archiving (riduce lo spazio); non registra il tipo di azione eseguita; ideale per auditare una o due colonne di una tabella.

Modello 3 – Historical auditing model: usato quando è richiesto un registro dell'intera riga; tipicamente usato in applicazioni finanziarie. Si crea una tabella APP_DATA_TABLE_HISTORY con la stessa struttura di APP_DATA_TABLE, dove ogni modifica genera una nuova riga storica.

Esempio: Database Auditing – SQL

```
-- MS SQL Server
CREATE SERVER AUDIT AuditDataAccess
  TO FILE ( FILEPATH = 'C:\SQLAudit\' )
  WHERE object_name = 'Employees';
ALTER SERVER AUDIT AuditDataAccess WITH (STATE = ON);

-- Oracle
CREATE AUDIT POLICY AuditDataAccess ACTIONS
  DELETE on Employees, INSERT on Employees,
  UPDATE on Employees, SELECT on Employees
  CONTAINER = CURRENT;
AUDIT POLICY AuditDataAccess;
```

Nota: IS e GDPR – Conclusione

Per rendere i sistemi informativi conformi al GDPR, occorre combinare più misure di sicurezza:

- Controllo degli accessi basato su attributi (**ABAC**)
- **Cifratura** (Always Encrypted / Transparent Data Encryption)
- **(Dynamic) Data Masking**
- **Auditing**

Domanda aperta: queste misure di sicurezza sono sufficienti a proteggere la privacy?

4 Controllo del Rilascio di Informazioni Statistiche (SDC)

Internet offre opportunità senza precedenti per raccogliere e condividere informazioni sensibili (web usage data, social media, smartphones, wearables). Spesso dati statistici vengono rilasciati per scopi legittimi:

- **Open data collegati:** per trasparenza pubblica.
- **Dataset per la riproducibilità scientifica:** per consentire la replica degli esperimenti.
- **Data Challenge/Contest:** come il Netflix Prize.
- **Policy/Regulation:** per scopi regolatori.

Tali dati rilasciati possono essere usati per inferire informazioni non destinate alla divulgazione, tramite linking attack, machine learning, data mining, inferenza statistica. Il **disclosure risk** dai dati rilasciati deve essere il più basso possibile.

4.1 Disclosure

Definizione: Disclosure

Un disclosure può occorrere:

- basandosi solamente sui dati rilasciati;
- risultando dalla combinazione dei dati rilasciati con informazioni pubblicamente disponibili;
- tramite combinazione con fonti esterne dettagliate (social media: Twitter, Facebook, YouTube, Instagram).

Esistono tre tipi di disclosure:

- **Identity disclosure:** una terza parte identifica direttamente il soggetto dai dati rilasciati. Per i *macrodata*: rivelare l'identità non è generalmente un problema, a meno che non conduca all'attribute disclosure. Per i *microdata*: l'identificazione è generalmente un problema perché i record sono dettagliati e l'identity disclosure implica quasi sempre l'attribute disclosure.
- **Attribute disclosure:** informazioni confidenziali su un soggetto vengono rivelate e possono essergli attribuite. Avviene quando le informazioni vengono rivelate esattamente o quando possono essere stimate con precisione. Comprende sia l'identificazione del soggetto sia la divulgazione di informazioni confidenziali a lui pertinenti.
- **Inferential disclosure** (o inferenziale): le informazioni possono essere inferite con alta confidenza tramite *proprietà statistiche* dei dati rilasciati. Esempio: i dati mostrano un'alta correlazione tra reddito e prezzo di acquisto della casa; poiché il prezzo di acquisto è informazione pubblica, un terzo potrebbe inferire il reddito. **Difficoltà:** se l'inferential disclosure equivale all'inferenza statistica, nessun dato potrebbe essere rilasciato; inoltre le inferenze predicono comportamenti aggregati, non valori individuali, quindi sono spesso predittori scarsi dei dati individuali.

I dati statistici si rilasciano come:

- **Macrodata:** aggregati in forma tabellare.

- **Tabelle Count/Frequency:** ogni cella contiene il numero (o la percentuale) di rispondenti con la stessa combinazione di valori degli attributi.
- **Tabelle Magnitude:** ogni cella contiene un valore aggregato (es. media) di una quantità di interesse.

I **rispondenti** sono aziende, autorità, persone fisiche, ecc., dai quali vengono raccolti i dati per produrre statistiche. Rivelare l'identità in macrodata è generalmente tollerabile, a meno che non conduca a un attribute disclosure.

- **Microdata:** grana fine, su singole persone/unità. Soggetti a maggiore rischio di data breach; l'identificazione implica quasi sempre anche l'attribute disclosure. I microdata includono spesso **identificatori espliciti** (nome, telefono, email, SSN) che devono essere rimossi come primo passo.

La riservatezza può essere protetta in due modi:

- **Restricted data:** limitare la quantità di informazioni nelle tabelle e nei microdata rilasciati.
- **Restricted access:** imporre condizioni sull'accesso ai prodotti dati.
- Combinazione delle due strategie.

Definizione: Statistical Disclosure Control (SDC)

È una collezione di metodi usati come parte del processo di anonimizzazione per controllare/limitare il rischio di re-identificazione e attribute disclosure tramite manipolazioni dei dati.

Importante: il disclosure control *non è privacy*. Tutti i processi che tentano di affrontare i rischi di disclosure sono principalmente processi tecnici di confidenzialità che si mappano *solo indirettamente e imperfettamente* sulle protezioni della privacy.

Il trade-off fondamentale: più alta è la disclosure risk, più alta è la data utility (e viceversa). **Il compromesso esiste sempre.** Il piano rischio/utilità ha due zone: **FORBIDDEN** (alto rischio, non rilasciabile) e **CONCEDED** (rischio accettabile). L'obiettivo è minimizzare il rischio mantenendo la massima utilità possibile, restando nella zona concessa.

Ciclo SDC ex-post (4 passi): Data → Metodo SDC (+scelta parametri euristici) → Misura di Utility → Misura di Rischio → (iterazione).

Analisi del rischio ex-ante: basata sul concetto di **privacy model**, ovvero una condizione (dipendente da un parametro) che garantisce un limite superiore al rischio di re-identificazione e attribute disclosure. I principali privacy model sono: *k*-anonymity, *l*-diversity, *t*-closeness, δ -presence, differential privacy.

Procedura SDC per microdata sicuri (Eurostat):

1. Definire i quasi-identificatori.
2. Decidere la soglia accettabile di combinazioni a bassa frequenza (es. al più 5% con frequenza 1 o 2 unità).
3. Calcolare le frequenze per le combinazioni di quasi-identificatori.
4. Eseguire una *global recode* sui quasi-identificatori (riduzione del numero di valori, es. per discretizzazione).

5. Applicare metodi SDC (es. micro-aggregazione) sulle variabili e record che richiedono protezione.
6. Eseguire *local suppression* sulle variabili identificative residue.
7. Ripetere i passi 3–6 fino a ottenere un livello accettabile di rischio e utilità.

4.2 Metodi SDC per Macrodata

- **Non-perturbativi:** non modificano i valori delle celle.
 - **Cell Suppression (CS):** soppressione delle celle a rischio (*primaria*); soppressione di celle aggiuntive per proteggere quelle primarie (*secondaria*).
- **Perturbativi:** modificano i valori delle celle.
 - **Random Rounding (RR):** arrotondamento casuale per difetto o per eccesso.
 - **Controlled Rounding (CR):** arrotondamento classico controllato.
 - **Controlled Tabular Adjustment (CTA):** i valori delle celle sensibili sono rimpiazzati da valori simili; le altre celle sono modificate di conseguenza per correggere i totali.

4.3 Metodi SDC per Dati Interrogabili (Query)

Tre approcci principali per i **Statistical Databases (SDB)** (ACM Computing Surveys, 1989):

1. **Query restriction:** l'SDB riceve query ristrette e risponde con valori esatti o nega la risposta. Richiede tracciamento delle query precedenti.
 2. **Data perturbation:** si genera una versione perturbata SDB' dei dati originali SDB; le query vengono eseguite su SDB' e rispondono con valori perturbati.
 3. **Output perturbation:** l'SDB riceve le query (ristrette) e risponde con valori perturbati.
- **Perturbativi:** perturbazione dell'input della query (applicata ai record) o dell'output (applicata al risultato della query).
 - **Restrittivi:** rifiuto di rispondere a certe query (query restriction); richiede di tenere traccia delle query precedenti.

4.4 Metodi SDC per Microdata

Data Masking Perturbativo

- **Aggiunta di rumore:** aggiungere a ogni record un rumore; media e correlazioni possono essere preservate.
- **Microaggregazioni:** partizionare i records in gruppi (basati su similarità); pubblicare solo la media per ogni gruppo.
- **Data swapping:** ordinare i valori per ogni attributo in ordine crescente; scambiare casualmente i valori in un range ristretto.
- **Post-randomizzazione:** cambia attributi categorici secondo determinate matrici di transizione.

Data Masking Non-Perturbativo

- **Sampling:** pubblicare un campione dei dati originali.
- **Generalizzazione:** attributi categorici combinati in categorie meno specifiche; attributi numerici sostituiti da intervalli.
- **Top/Bottom coding:** valori sopra/sotto un threshold sostituiti da un estremo.
- **Soppressione locale:** alcuni attributi/celle vengono soppressi; aumenta la dimensione dei gruppi.

Sintesi dei Dati (Synthetic Data)

- **Fully Synthetic Data:** sintetizzare tutto il dataset.
- **Partially Synthetic Data:** sintetizzare solo le variabili sensibili.
- Problemi: i dati sintetizzati devono mantenere validità statistica; overfitting $\Rightarrow$ rischio di re-identificazione.

4.5 Misura della Perdita di Informazioni: KL e JS

Misura della utilità: la misura dell'utilità è difficile perché spesso non è chiaro a priori cosa gli utenti vogliano fare con i dati. Si usa la nozione di **information loss**: tenta di catturare in termini information-theoretic la variazione di informazione causata dal disclosure control.

Information loss per macrodata:

- **Cell suppression:** numero o magnitudine aggregata delle soppressioni secondarie.
- **Rounding e tabular adjustment:** somma delle distanze tra celle vere e celle perturbate (eventualmente pesata per l'importanza delle celle).

Information loss per query:

- **Query perturbation:** differenza tra risposta vera e risposta perturbata (media dovrebbe essere zero, varianza piccola).
- **Query restriction:** numero di query rifiutate.

Information loss per microdata:

- **Data use-specific:** valuta quanto il SDC impatta l'output di analisi specifiche.
- **General information loss:** statistiche di base (medie, covarianze, correlazioni); propensity scores (PSM – metodo quasi-sperimentale); distanza tra dati originali e disclosure-controlled con KL o JS.

Definizione: Divergenza Kullback-Leibler (KL)

Misura quanto una distribuzione di probabilità perturbata $P(x)$ sia diversa dalla distribuzione originaria $Q(x)$ (entropia relativa di P rispetto a Q):

$$KL(P\|Q) = \sum_{x \in X} P(x) \log \left(\frac{P(x)}{Q(x)} \right)$$

Nota: KL non è simmetrica ($KL(P\|Q) \neq KL(Q\|P)$ in generale).

Definizione: Divergenza Jensen-Shannon (JS)

Versione simmetrizzata e smoothed di KL:

$$JS(P\|Q) = \frac{1}{2}KL(P\|M) + \frac{1}{2}KL(Q\|M), \quad M = \frac{1}{2}(P + Q)$$

JS è sempre definita, simmetrica e $0 \leq JS \leq 1$.

5 Framework di Anonimizzazione

5.1 Il Problema dell'Anonimità e il Linking Attack

Definizione: Quasi-Identificatori – Tore Dalenius, 1986

I quasi-identificatori sono attributi che non sono univoci di per sé, ma che **combinati con altri quasi-identificatori** possono creare un identificatore univoco.

I ruoli degli attributi nei microdata:

- **Identificatori espliciti:** nome, SSN, etc. – vengono rimossi (*sanitizzazione*).
- **Quasi-identificatori:** attributi che possono essere usati per re-identificare individui.
- **Attributi sensibili:** portano informazioni sensibili (diagnosi, stipendio, etc.).

Esempio: Linking Attack di Sweeney (2001)

Il Massachusetts pubblica dati medici sanitizzati (rimossi nome e SSN) degli impiegati statali. La lista elettorale del Massachusetts (pubblicamente disponibile) contiene: nome, indirizzo, data di nascita, partito, etc. Sweeney incrocia i due dataset usando {ZIP, sesso, data di nascita} come chiave di join e re-identifica il record medico del governatore William Weld. I dettagli: 6 persone avevano la sua data di nascita, 3 erano uomini, 1 solo era nel suo CAP. **L'87% della popolazione USA** (1990 census) è unicamente identificabile da {ZIP, sesso, data di nascita completa}.

Esempio: Statistiche Re-identificazione – US Census 2000

Nel censimento USA del 2000, la percentuale di popolazione unicamente identificabile in base a diverse combinazioni di attributi risulta:

Attributi usati	Popolazione identificabile
Anno di nascita + ZIP a 5 cifre	0,2%
Anno di nascita + nazione	0,0%
Anno e mese di nascita + ZIP a 5 cifre	4,2%
Anno e mese di nascita + nazione	0,2%
Anno, mese e giorno di nascita + ZIP a 5 cifre	63,3%
Anno, mese e giorno di nascita + nazione	14,8%

Questi dati mostrano come la data di nascita completa combinata con il codice postale sia sufficiente a identificare quasi i 2/3 della popolazione.

Nota: Obiettivo della Privacy nei Microdata

Il **goal della privacy preservation** (definizione operativa) è **de-associare** gli individui dalle loro informazioni sensibili. Nei microdata, i tre ruoli degli attributi sono:

- **Identificatori espliciti** (es. Nome, SSN): vengono *rimossi* tramite sanitizzazione.
- **Quasi-identificatori** (es. Data di nascita, Sesso, ZIP): possono essere usati per re-identificare un individuo combinandoli con dati pubblici.
- **Attributi sensibili** (es. Diagnosi, Malattia): possono non esistere; portano informazioni che si vuole proteggere.

Non è facile elencare tutti i quasi-identificatori e i dati sensibili: esistono **attributi proxy**, apparentemente innocui, che correlano con dati sensibili (es. ZIP code correla con la razza; livello di istruzione correla con il genere).

5.2 K-Anonymity

Definizione: K-Anonymity – Samarati & Sweeney, 1998

Sia T un dataset su un insieme $A = a_1, \dots, a_n$ di attributi e QI_T l'insieme dei quasi-identificatori di T . T soddisfa la k -anonymity se e solo se per ogni quasi-identificatore $QI \in QI_T$, ogni sequenza esistente di valori attribuita a QI compare almeno con k occorrenze in T .

Proprietà: ogni individuo si nasconde in $k - 1$ altri individui; i linking attack non possono essere effettuati con confidenza superiore a $\frac{1}{k}$.

Tecniche per ottenere la k -anonymity:

- **Generalizzazione**: il valore di un dato attributo è rimpiazzato da uno più generale (es. ZIP 10149 $\rightarrow$ 101 **; data di nascita 27/09/1964 $\rightarrow$ 1964).
- **Soppressione**: proteggere informazioni sensibili rimuovendole (rimozione di tuple outlier).

La k -anonymity richiede che ogni release dei dati sia tale che ogni combinazione di valori dei quasi-identificatori possa essere associata in modo indistinto ad almeno k rispondenti. La **condizione sufficiente** per garantire questo è che ogni insieme di valori dei quasi-identificatori nella tabella rilasciata appaia almeno k volte (*gli attributi sensibili non sono considerati*).

Nota: Proxy Attributes – difficoltà nell'elencare i QI

Non è facile identificare tutti i quasi-identificatori e i dati sensibili, perché esistono attributi *proxy* che sono correlati ai dati sensibili pur sembrando innocui. Esempi (da Caton & Haas, Fairness in Machine Learning, arXiv 2020):

Variabile Sensibile	Proxy Attributes
Genere	Livello di istruzione, Reddito, Occupazione, Dati penali, Parole chiave in UGC (CV, Social Media), Ore lavorative
Stato civile	Livello di istruzione, Reddito
Razza	Dati penali, Parole chiave in UGC, ZIP code
Disabilità	Dati Personality Test

Nota: Privacy vs. Utilità nella K-Anonymity

I dati anonimizzati vengono rilasciati per scopi di analisi statistica. Se i dati sono “troppo anonimi” diventano inutili. Il principio fondamentale è: **non anonimizzare più del necessario!**

Questo rispecchia il trade-off generale SDC: zona VIETATA (disclosure risk troppo alto) vs. zona CONCESSA (dati troppo degradati per essere utili).

Il problema di trovare la tabella con la **minima generalizzazione** che soddisfi la k-anonymity è **NP-hard**. La maggior parte degli algoritmi ha complessità esponenziale nel numero di valori degli attributi.

Definizione: Domain Generalization Hierarchy (DGH)

Una gerarchia di generalizzazione su un dominio (DGH_D) di un attributo A è un ordine parziale su un insieme di domini $Dom_A = \{D_0, \dots, D_n\}$ tale che:

- Ogni dominio D_i ha al più una generalizzazione diretta.
- Tutti gli elementi massimi di Dom sono singletons (per far sì che ogni valore possa essere generalizzato in un singolo valore).

Il prodotto cartesiano delle DGH di tutti gli attributi forma un **reticolo di generalizzazione** DGH_{DT} .

Nota: In parole semplici: DGH e Reticolo di Generalizzazione

La DGH definisce i **livelli di astrazione** disponibili per ogni attributo – non i singoli valori, ma i *domini* in cui questi valori vivono. Per lo ZIP, ad esempio: D_0 = dominio di tutti i codici a 5 cifre esatte (53715, 53710, ...); D_1 = dominio dei codici a 4 cifre + * (5371*, 5370*, ...); D_2 = dominio dei codici a 3 cifre + **; e così via fino a $D_n = \{*****\}$. La DGH dice semplicemente come questi livelli si ordinano: $D_0 \rightarrow D_1 \rightarrow \dots \rightarrow D_n$ (ogni livello è meno specifico del precedente). Il **reticolo** è il prodotto cartesiano di tutte le DGH degli attributi: ogni nodo del reticolo rappresenta una *combinazione di livelli* (es. ZIP al livello D_1 , età al livello D_0 originale, sesso al livello D_1). Muoversi verso l'alto nel reticolo significa generalizzare di più e perdere informazione; restare in basso significa conservare il dettaglio ma rischiare di violare la k-anonymity.

Definizione: Value Generalization Hierarchy (VGH)

Per ogni dominio D , la **gerarchia di generalizzazione dei valori** VGH_D è un **albero** dove:

- Le **foglie** sono i valori nel dominio D (i valori più specifici).
- La **radice** è il valore nell'elemento massimale di DGH_D (il valore più generale).

VGH_D è determinato dalla relazione di generalizzazione dei valori, che associa a ogni valore $v_i \in D_i$ un unico valore $v_j \in D_j$ (con D_j generalizzazione diretta di D_i). Esempio ZIP: 53715, 53710 $\rightarrow$ 5371*; 53706, 53703 $\rightarrow$ 5370*; 5371*, 5370* $\rightarrow$ 537**.

Nota: In parole semplici: VGH

La VGH è concretamente l'albero in cui le foglie sono i valori più specifici (es. 53715, 53710) e salendo i valori si fondono in categorie sempre più generali (es. 5371*, 537**, *****). È come fare zoom-out su una mappa: più sali, meno dettagli vedi. Ogni attributo del dataset ha il suo albero VGH; la DGH cataloga quali livelli (domini) esistono, e la VGH dice esattamente come ogni valore si generalizza.

Definizione: Vettore Distanza (Distance Vector)

Siano T_i e T_j due tabelle definite sugli stessi attributi $A = \{A_1, \dots, A_n\}$ tali che $T_i \leq T_j$. Il **vettore distanza** di T_j da T_i è $DV_{ij} = [d_1, \dots, d_n]$, dove ogni d_x è la lunghezza del cammino unico tra $dom(A_x, T_i)$ e $dom(A_x, T_j)$ nella DGH_{Dx} .

Esempio: se Ethnicity ha DGH con 2 livelli ($E_0 \rightarrow E_1$) e ZIP ha DGH con 3 livelli ($Z_0 \rightarrow Z_1 \rightarrow Z_2$), allora la tabella con Ethnicity in E_1 e ZIP in Z_1 ha $DV = [1, 1]$ rispetto alla tabella originale.

Nota: In parole semplici: Vettore Distanza

Il vettore distanza misura semplicemente quanti “passi verso l'alto” nell'albero di generalizzazione sono stati fatti per ciascun attributo. $DV = [1, 2]$ significa: etnia generalizzata di 1 livello, ZIP generalizzato di 2 livelli. Serve per confrontare diverse soluzioni di anonimizzazione e scegliere quella che generalizza il *meno* possibile mantenendo però la k-anonymity – ovvero quella che perde meno informazione.

Nota: Classificazione delle Tecniche di K-Anonymity

La generalizzazione e la soppressione possono essere applicate a diversi livelli di granularità:

- **Generalizzazione:** a livello di *colonna* (un passo generalizza tutti i valori della colonna) oppure a livello di *singola cella* (una colonna può contenere valori a livelli di generalizzazione diversi).
- **Soppressione:** a livello di *riga* (rimuove una tupla intera), a livello di *colonna* (oscura tutti i valori di una colonna) oppure a livello di *singola cella* (oscura solo certe celle di una tupla/attributo).

Definizione: K-Minimal Generalization with Suppression

Date due tabelle $T_i \leq T_j$ (con T_j generalizzazione di T_i) e MaxSup il threshold di soppressione accettabile, T_j è una generalizzazione k-minima di T_i se e solo se: T_j soddisfa la k-anonymity; la soppressione è minimale; $|T_j| - |T_i| \leq MaxSup$; non esiste T_x con $T_i \leq T_x \leq T_j$ che soddisfi gli stessi criteri con vettore distanza minore.

5.2.1 Algoritmo di Samarati

Definizione: Samarati's Algorithm

Ogni percorso in DGH_{DT} rappresenta una strategia di generalizzazione. L'algoritmo si basa su una generalizzazione minima locale (il nodo minore di ogni percorso che soddisfa la k-anonymity). Effettua una **ricerca binaria** sul reticolo dei vettori distanza:

1. Valuta tutte le soluzioni ad altezza $h/2$.
2. Se esiste almeno una soluzione: valuta a $h/4$; altrimenti a $3h/4$.
3. Ripeti fino a raggiungere l'altezza minore per cui esiste un vettore distanza che soddisfa la k-anonymity.

Proprietà: salendo nella gerarchia il numero di tuple da rimuovere per la k-anonymity decresce. Se non esiste soluzione all'altezza h con $\leq MaxSup$ soppressioni, non ne esiste una ad altezza minore (approccio branch and bound).

Nota: In parole semplici: Algoritmo di Samarati

Invece di provare tutti i livelli di generalizzazione uno per uno (dal meno al più generico), l'algoritmo fa una ricerca binaria: parte dal livello medio $h/2$ del reticolo. Se lì si soddisfa la k-anonymity con un numero accettabile di soppressioni, allora prova a scendere (meno generalizzazione = più dettaglio); altrimenti sale (più generalizzazione). In questo modo trova il livello minimo necessario in $\log_2(h)$ iterazioni invece di h – molto più efficiente.

5.2.2 Algoritmo Incognito

Definizione: Incognito Algorithm

Adotta un approccio **bottom-up** per la visita delle *DGH*. La proprietà di k-anonymity rispetto a un sottoinsieme *QI* è una condizione *necessaria* per la k-anonymity rispetto a *QI* completo (**monotonicità nel reticolo**).

1. **Iterazione 1:** controlla la k-anonymity per ogni singolo attributo in *QI*, scartando le generalizzazioni che non la soddisfano.
2. **Iterazione 2:** combina le rimanenti generalizzazioni in coppie e controlla.
3. **Iterazione i:** combina tutte le *i*-uple e controlla.
4. **Iterazione $|QI|$:** risultato.

Incognito sfrutta due proprietà di monotonicità nel reticolo (analoghe ad Apriori nel frequent itemset mining):

- **Proprietà di Generalizzazione (rollup):** se la k-anonymity vale in un nodo del reticolo, vale anche per qualsiasi nodo antenato (generalizzazione di più attributi). Equivalentemente: la k-anonymity rispetto a un *QI* implica k-anonymity rispetto a qualsiasi sottoinsieme di *QI*.
- **Proprietà di Sottoinsieme (apriori):** se la k-anonymity *non* vale per un insieme di attributi *QI*, non può valere per nessuno dei suoi superset (più attributi $\Rightarrow$ gruppi più piccoli $\Rightarrow$ più difficile soddisfare k-anonymity).

Incognito considera insiemi di attributi *QI* di cardinalità crescente e pota i nodi del reticolo usando queste due proprietà.

Nota: In parole semplici: Algoritmo Incognito

L'intuizione è: prima di verificare la k -anonymity su tutti gli attributi insieme (operazione costosa), verifica ogni singolo attributo da solo. Se già un solo attributo preso individualmente viola la k -anonymity, allora qualunque combinazione che lo includa la violerà sicuramente – aggiungere attributi crea gruppi ancora più piccoli. Questo taglia enormemente lo spazio di ricerca, esattamente come l'algoritmo Apriori nel frequent itemset mining: se un insieme piccolo è problematico, tutti i suoi soprainsieme lo saranno.

5.3 Oltre la K-Anonymity

5.3.1 Attacchi alla K-Anonymity

- **Homogeneity attack:** può accadere quando tutte le tuple con i quasi-identificatori in una tabella k -anonimizzata hanno gli stessi valori di attributi sensibili.
- **Background knowledge attack:** si basa su conoscenza pregressa con informazioni esterne per eliminare valori sensibili possibili.

Esempio: Homogeneity Attack – Carol

Si consideri una tabella 4-anonima. Un attaccante sa che Carol è una donna americana di 31 anni che vive nel ZIP 13053. Cerca il suo gruppo nella tabella anonimizzata e trova 4 record con ZIP 130**, età 3*, nazionalità *. Tutti e 4 i record del blocco hanno Disease = Cancer. Nonostante la 4-anonymity, l'attaccante può concludere con certezza che **Carol ha il cancro**.

Esempio: Background Knowledge Attack – Hellen

Un attaccante sa che Hellen è una donna americana di 29 anni che vive nel ZIP 13068, e sa anche che è una sportiva. Nella tabella 4-anonima, il blocco con ZIP 130**, età <30 contiene Heart Disease e Viral Infection. Poiché le sportive raramente contraggono infezioni virali, l'attaccante può inferire che **Hellen soffre di Heart Disease**. Questo è un caso di negative disclosure: l'attaccante *elimina* valori sensibili possibili tramite conoscenza di background.

Nota: anche *senza* conoscenza di background, l'attaccante può dedurre che Hellen **non ha il cancro**, poiché nel suo blocco non appare Cancer (negative disclosure pura).

Una tabella può rilasciare informazioni in due modi:

- **Positive disclosure:** pubblicando i valori della tabella si può identificare con alta probabilità una persona.
- **Negative disclosure:** pubblicando i valori della tabella si possono eliminare correttamente alcuni dei possibili valori (se iterata può portare a positive disclosure).

5.3.2 L-Diversity

Nota: In parole semplici: Notazione L-Diversity

Prima di entrare nella notazione formale, l'idea è semplice: un q^* -**block** è il gruppo di persone che, dopo la generalizzazione, hanno gli stessi valori per i quasi-identificatori (es. tutti quelli con ZIP 130** e età 3*). La k -anonymity garantisce che ogni gruppo abbia almeno k persone. L' l -diversity aggiunge che dentro ciascun gruppo i valori sensibili (es.

malattie) devono essere almeno l valori diversi e distribuiti abbastanza uniformemente – così, anche se sai che qualcuno appartiene a quel gruppo, non puoi dedurre la malattia con certezza.

Notazione formale: Siano PT la tabella privata e GT la tabella generalizzata rilasciata.

- q : valore di un attributo non sensibile Q in PT.
- q^* : valore generalizzato di q in GT.
- s : possibile valore dell'attributo sensibile S .
- $n(q^*, s)$: numero di tuple $t^* \in GT$ tali che $t^*[Q] = q^*$ e $t^*[S] = s$.
- **q^* -block** (classe di equivalenza): l'insieme delle tuple in GT i cui valori non sensibili di Q si generalizzano a q^* .

Definizione: L-Diversity – Machanavajjhala et al., 2006

Un q^* -block (classe di equivalenza) è l -diverso se ha almeno $l \geq 2$ diversi valori sensibili ben rappresentati (il valore l più frequente ha all'incirca la stessa frequenza degli altri). Una tabella è l -diversa se ogni q^* -block è l -diverso.
Formalmente: mancanza di diversità si ha quando $\forall s' \neq s, n(q^*, s') \ll n(q^*, s)$.
La l -diversity assicura la diversità richiedendo che ogni blocco abbia almeno l valori sensibili ben rappresentati.

Definizione: Entropy L-Diversity

Una tabella GT l -diversa è basata sull'entropia se per ogni q^* -block:

$$-\sum_{s \in S} p(q^*, s) \log(p(q^*, s)) \geq \log(l)$$

dove $p(q^*, s) = \frac{n(q^*, s)}{\sum_{s' \in S} n(q^*, s')}$ è la frazione di tuple nel q^* -block con attributo sensibile uguale a s .

Proprietà: la entropy l -diversity soddisfa la *monotonicità* $\Rightarrow$ qualsiasi algoritmo per la k -anonymity può essere esteso per assicurare l -diversity.

Nota: In parole semplici: Entropy L-Diversity

L'entropia è una misura di “disordine” o “varietà”: è alta quando i valori sensibili sono distribuiti in modo uniforme nel blocco, e bassa quando uno solo domina (es. se nel blocco 9 persone su 10 hanno Cancer e 1 sola ha Flu, c'è poca diversità). Richiedere che l'entropia sia $\geq \log(l)$ è più forte della semplice presenza di l valori diversi: impone che la distribuzione sia *almeno tanto varia* quanto se fossero l valori equiprobabili. Questo previene situazioni in cui ci sono formalmente l malattie diverse, ma una schiacciante maggioranza e quindi è facile indovinarla.

L-Diversity e Background Knowledge: se ci sono l valori sensibili ben rappresentati in un q^* -block, l'attaccante ha bisogno di $l - 1$ pezzi di conoscenza di background per eliminare $l - 1$ valori sensibili possibili e inferire una positive disclosure. Impostando il parametro l , il data publisher determina quanta protezione si vuole offrire contro la conoscenza di background (anche se questa è sconosciuta al publisher).

Attacchi alla L-Diversity:

- **Skewness attack:** quando la distribuzione del q -block è diversa dalla distribuzione nella popolazione originale (un valore sensibile potrebbe essere molto più comune nella popolazione ma ugualmente rappresentato nel blocco).
- **Similarity attack:** quando un q -block ha valori diversi ma semanticamente simili per i valori sensibili (es. tutti i tipi di cancro).

5.3.3 δ -Presence

Il problema della Membership Disclosure: la k -anonymity protegge dall'identificazione dell'individuo nel dataset, ma **potrebbe non nascondere** se un dato individuo è presente nel dataset. Con alta probabilità, il quasi-identificatore di un individuo è unico nella popolazione; generalizzare/sopprimere i QI nel dataset *non* cambia la loro distribuzione nella popolazione. Se il dataset anonimizzato contiene 10 record con un certo QI e ci sono 10 persone nella popolazione che corrispondono a quel QI, sapere che l'individuo è nel dataset rivela informazioni (es. ha quella malattia).

Problemi pratici dove la *membership disclosure* è critica:

- **Counter-terrorism:** DB di gruppi terroristici sospetti per ricerca – rivelare che una persona è nel DB è dannoso.
- **Ricerca medica:** DB di pazienti con un tipo particolare di cancro – rivelare che una persona è nel DB ne svela la diagnosi.

Definizione: δ -Presence – Nergiz, Atzori, Clifton, SIGMOD 2007

Siano T una tabella pubblica esterna, PT la tabella privata (sottoinsieme di T), e GT la generalizzazione di PT rilasciata pubblicamente. La δ -presence vale per GT rispetto a PT , con $\delta = (\delta_{min}, \delta_{max})$, se:

$$\delta_{min} \leq P(t \in PT \mid GT) \leq \delta_{max} \quad \forall t \in T$$

dove $\delta = (\delta_{min}, \delta_{max})$ è un range di probabilità accettabili per $P(t \in PT \mid GT)$. In tale dataset si dice che ogni tupla $t \in T$ è δ -presente in PT .

Intuizione: la probabilità che un individuo sia nella tabella privata deve rimanere entro un range controllato – non troppo alta (rischio di sapere che è presente) né troppo bassa (rischio di sapere che è assente). Esempio tipico: $\delta = [1/3, 2/3]$.

Nota: In parole semplici: δ -Presence

Il problema che risolve la δ -presence è: “Posso capire dal dataset pubblicato se una certa persona è nel database privato?” (anche senza sapere quale malattia ha – sapere che sei in un DB di pazienti oncologici già rivela molto). La δ -presence richiede che la probabilità di essere incluso nel DB privato resti sempre entro un intervallo $[\delta_{min}, \delta_{max}]$: non troppo alta (altrimenti l'avversario deduce che sei sicuramente nel DB) e non troppo bassa (altrimenti deduce che di sicuro non ci sei). Esempio: se tutti gli “americani” nel dataset generalizzato hanno probabilità $1/2$ di essere nel DB privato, l'avversario sa solo che c'è una chance su due – non impara niente di più rispetto a prima.

Esempio: δ -Presence – Tabella GT e sottoinsieme PT

Tabella pubblica T con 9 individui (a–i); tabella privata PT (sottoinsieme di T) con 5 individui (b, c, f, h, i). La generalizzazione GT rilasciata sopprime Age e generalizza ZIP:

ID	ZIP	Age	Nationality	Sens.
a	47*	*	America	0
b	47*	*	America	1
c	47*	*	America	1
d	47*	*	America	0
e	47*	*	America	0
f	47*	*	America	1
g	48*	*	Europe	0
h	48*	*	Europe	1
i	48*	*	Europe	1

GT è una $(\frac{1}{2}, \frac{2}{3})$ -generalizzazione di PT: tra i 6 individui America di T, 3 sono in PT $\Rightarrow P = \frac{1}{2}$; tra i 3 individui Europe, 2 sono in PT $\Rightarrow P = \frac{2}{3}$.

Teorema: Monotonicità della δ -Presence

Siano T una tabella pubblica, PT la tabella privata, GT^1 una generalizzazione di PT e GT^2 una generalizzazione di GT^1 . Se GT^1 è $(\delta_{min}, \delta_{max})$ -present rispetto a T e PT, allora lo è anche GT^2 .

Equivalentemente: **se GT^2 non è δ -present rispetto a T e PT, allora non lo è nemmeno GT^1 .**

Questa proprietà (analoga alla monotonicità della k-anonymity) permette di sfruttare la maggior parte degli algoritmi per la k-anonymity anche per il calcolo della δ -presence.

Esempio: Selezione di un buon δ – Caso Diabete

Sia rilasciato un dataset PT di pazienti diabetici, sottoinsieme di una tabella pubblica T. Sia I_p l'evento "la persona p ha il diabete". Poiché il tasso di diabete nella popolazione USA è pubblico, un avversario ha una *prior belief* $b_r = P(I_p) = 0.07$.

Dopo aver visto la generalizzazione GT, l'avversario aggiorna la sua credenza a *posterior belief* $b_0 = P(I_p | GT)$:

$$b_0 = P(I_p | p \in PT) \cdot P(p \in PT | GT) + P(I_p | p \notin PT) \cdot P(p \notin PT | GT)$$

Poiché PT contiene solo malati, $P(I_p | p \in PT) = 1$; per chi non è in PT la probabilità che sia diabetico è $b_r \cdot \frac{|T|-|PT|}{|T|-|PT|} = b_r$. Sostituendo (eq. 1):

$$b_0 = \delta \cdot \frac{|T|(1 - b_r)}{|T| - |PT|} + \frac{b_r \cdot |T| - |PT|}{|T| - |PT|}$$

dove $\delta = P(p \in PT | GT)$.

Stima di δ_{max} : il costo di un uso improprio è $d = \$10,000/\text{anno}$ per paziente. Si vuole che il costo atteso aggiuntivo rispetto alla prior sia $< c = \$100$:

$$b_0 \cdot d - b_r \cdot d < c \quad \Rightarrow \quad b_0 - b_r < \frac{c}{d} = \frac{1}{100} \quad \Rightarrow \quad b_0 < \frac{1}{100} + b_r$$

Con $|PT| \approx 0.04|T|$ e $b_r = 0.07$, sostituendo nella eq. 1 si ottiene $\delta_{max} = P(p \in PT | GT) \approx 0.05$.

Stima di δ_{min} : la posterior non deve essere arbitrariamente bassa (altrimenti un avversario "cherry-pick" persone note per non essere nel DB). Si impone $b_0 \geq b_r$:

$$b_0 = b_r = 0.07 = \delta \cdot 0.97 + 0.03 \quad \Rightarrow \quad \delta = \frac{0.07 - 0.03}{0.97} = 0.04 = \delta_{min}$$

Quindi: $\forall p : P(p \in PT \mid GT) \in [0.04, 0.05]$, cioè $\delta = (0.04, 0.05)$.

Nota: Limiti degli approcci k-anonymity

- **Misure di utilità:** è necessario sviluppare misure per consentire agli utenti di valutare, oltre alla protezione offerta, l'*utilità* dei dati rilasciati.
- **Algoritmi efficienti:** calcolare una tabella che soddisfi la k-anonymity garantendo la minimalità è un problema NP-hard; la maggior parte degli algoritmi ha complessità esponenziale.
- **Fusione di tabelle e viste:** la k-anonymity assume l'esistenza di un'unica tabella da rilasciare con al più una tupla per rispondente. Nella realtà più tabelle o viste possono essere combinate dall'avversario.
- **Conoscenza esterna:** la k-anonymity non modella la conoscenza esterna che può essere usata per inferenza, esponendo i dati a identity o attribute disclosure.

Nota: Curse of Dimensionality – Aggarwal, VLDB 2005

La generalizzazione si basa fondamentalmente sulla **località spaziale**: ogni record deve avere k vicini “abbastanza simili”. Nei dataset reali con molti attributi questo diventa impossibile:

- I dataset reali sono molto **sparsi**: Netflix Prize dataset ha 17.000 dimensioni, i record di clienti Amazon hanno milioni di dimensioni.
- Il “vicino più prossimo” è molto lontano in alta dimensione.
- La proiezione a bassa dimensione perde tutta l'informazione.

Conseguenza: i dataset k-anonimizzati in alta dimensione sono **praticamente inutili** perché la generalizzazione richiesta è eccessiva.

6 Privacy Differenziale

6.1 Definizione Formale

Introdotta da **Cynthia Dwork** nel 2006 (“Calibrating Noise to Sensitivity in Private Data Analysis”). La DP è un framework matematico per rilasciare informazioni statistiche proteggendo contemporaneamente il dataset. Il modello è totalmente astratto rispetto alle caratteristiche implementative.

Nota: Definizione informale – Cynthia Dwork

“Differential Privacy describes a promise, made by a data holder, or curator, to a data subject (owner), and the promise is like this: You will not be affected adversely or otherwise, by allowing your data to be used in any study or analysis, no matter what other studies, datasets or information sources are available.”

Idea fondamentale: pubblicare il risultato esatto di una query $q : \Omega \rightarrow \mathcal{R}$ può rivelare troppe informazioni sul dataset segreto D . L'idea chiave della DP è iniettare una qualche forma di casualità nel calcolo di $q(D)$, ottenendo un risultato distorto $\tilde{q}(D)$. In questo modo è impossibile determinare con certezza se il dataset segreto era D o un qualunque altro dataset simile D' .

Per fare ciò si utilizza un **meccanismo randomizzato** $\mathcal{M} : \Omega \times Q \rightarrow \mathcal{R}$, $(D, q) \mapsto \tilde{q}(D)$ – una funzione stocastica che può restituire qualsiasi valore del codominio $\mathcal{R}$ con la propria probabilità.

Definizione: Meccanismo Randomizzato

Un meccanismo randomizzato è una funzione $\mathcal{M} : \Omega \times Q \rightarrow \mathcal{R}$ che mappa un database D e una query q a una risposta randomizzata $\tilde{q}(D)$.

Due dataset D e D' si dicono **adiacenti** ($D \sim D'$) se differiscono per esattamente un record.

Definizione: ε -Differential Privacy

Un meccanismo $\mathcal{M} : \Omega \times Q \rightarrow \mathcal{R}$ preserva la ε -differential privacy, con $\varepsilon > 0$, se per qualsiasi query q , per ogni coppia di dataset adiacenti $D, D' \in \Omega$ e per ogni possibile risposta $r \in \mathcal{R}$:

$$e^{-\varepsilon} \leq \frac{\mathbb{P}(\mathcal{M}(q, D) = r)}{\mathbb{P}(\mathcal{M}(q, D') = r)} \leq e^{\varepsilon}$$

Il parametro ε è il **privacy budget**: più piccolo è, maggiore è la garanzia di privacy. Per $\varepsilon \rightarrow 0$ le probabilità sono quasi uguali (massima privacy, minima utility).

Nota: In parole semplici: ε -Differential Privacy

La definizione formale dice: aggiungere o togliere un solo record dal dataset non deve cambiare la probabilità di qualsiasi output di più di un fattore $e^{\varepsilon} \approx 1 + \varepsilon$ (per ε piccolo). In pratica: un avversario che osserva il risultato della query non riesce a capire con certezza se il tuo record era nel dataset oppure no. Più ε è piccolo, più il meccanismo deve aggiungere rumore per oscurare la tua presenza – ma meno precisa sarà la risposta. Con ε grande il rumore è minimo ma la privacy è debole. Il **privacy budget** è proprio questo: ogni query “spende” un po’ di ε , e una volta esaurito non si può più interrogare il dataset in modo privato.

Nota: Privacy vs. Accuracy

Un meccanismo che restituisce sempre la stessa costante (es. $\mathcal{M} : D \mapsto 100$) soddisfa la DP con $\varepsilon = 0$, poiché $P(\mathcal{M}(D) = 100) = 1 = P(\mathcal{M}(D') = 100) \cdot e^0$ per ogni coppia di dataset adiacenti. Tuttavia è **completamente inutile**: non fornisce alcuna informazione sul dataset reale. Questo evidenzia il fondamentale **trade-off privacy–utilità**: minimizzare ε aumenta la privacy ma riduce la qualità delle risposte, e viceversa.

Definizione: Global Sensitivity L1

$$GS_1(q) = \max_{D \sim D'} \|q(D) - q(D')\|_1$$

Per una singola query numerica: $GS_1(q) = \max_{D \sim D'} |q(D) - q(D')|$.

Nota: In parole semplici: Global Sensitivity

La sensibilità globale risponde alla domanda: “Di quanto può cambiare al massimo la risposta alla mia query se aggiungo o rimuovo un singolo record?” Due esempi chiari:

- Query **COUNT** (“quanti record ci sono?”): aggiungere o rimuovere un record cambia il risultato esattamente di 1 $\Rightarrow GS_1 = 1$.
- Query **SUM** (“qual è la somma degli stipendi?”): aggiungere un record con stipendio

s cambia la somma di s ; nel caso peggiore s è il valore massimo del dominio $\Rightarrow GS_1 = \max(\text{stipendio})$.

Il meccanismo di Laplace aggiunge rumore proporzionale a GS_1/ε : più la query è sensibile (grande GS_1) o più privacy vuoi (piccolo ε), più grande sarà il rumore aggiunto.

6.2 Meccanismo di Laplace

Teorema: Meccanismo di Laplace

Il meccanismo di Laplace aggiunge rumore estratto da una distribuzione di Laplace calibrata alla sensibilità:

$$\mathcal{M}_{Lap}(D, q) \mapsto q(D) + Lap\left(0, \frac{GS_1(q)}{\varepsilon}\right)$$

La PDF di $Lap(\mu, b)$ è: $f(x) = \frac{1}{2b}e^{-|x-\mu|/b}$.

Il meccanismo di Laplace preserva la ε -differential privacy.

Dimostrazione: Siano $D, D' \in \Omega$ due dataset adiacenti e $q(\cdot)$ una query $q : \Omega \rightarrow \mathcal{R}$. Siano p_D e $p_{D'}$ le PDF di $\mathcal{M}_{Lap}(q, D)$ e $\mathcal{M}_{Lap}(q, D')$ rispettivamente. Per un risultato arbitrario $r \in \mathbb{R}$:

$$\frac{p_D(r)}{p_{D'}(r)} = \frac{e^{-\frac{\varepsilon|q(D)-r|}{GS_1(q)}}}{e^{-\frac{\varepsilon|q(D')-r|}{GS_1(q)}}} = e^{\frac{\varepsilon(|q(D')-r|-|q(D)-r|)}{GS_1(q)}}$$

Per la disuguaglianza triangolare: $|q(D') - r| - |q(D) - r| \leq |q(D') - q(D)| = \|q(D') - q(D)\|_1$. Poiché $GS_1(q) = \max_{D \sim D'} \|q(D) - q(D')\|_1$ e D, D' sono adiacenti, si ha $\|q(D') - q(D)\|_1 \leq GS_1(q)$, quindi:

$$\frac{p_D(r)}{p_{D'}(r)} \leq e^{\frac{\varepsilon \cdot GS_1(q)}{GS_1(q)}} = e^\varepsilon \quad \square$$

Estensione al caso vettoriale: Il meccanismo di Laplace si estende a query che restituiscono un vettore numerico $q : \Omega \rightarrow \mathbb{R}^n$. Si aggiunge rumore Laplace indipendente a ciascuna componente:

$$\mathcal{M}_{Lap}(q, D) = q(D) + (X_1, \dots, X_n), \quad X_i \sim Lap\left(0, \frac{GS_1(q)}{\varepsilon}\right) \text{ i.i.d.}$$

Nota: In parole semplici: Meccanismo di Laplace e sua dimostrazione

L'idea è semplice: invece di pubblicare il valore esatto $q(D)$, si pubblica $q(D) + \text{rumore}$, dove il rumore viene estratto da una distribuzione di Laplace centrata in 0. Più la query è "sensibile" (grande GS_1) e più privacy vuoi (piccolo ε), più grande è il rumore. La **dimostrazione** usa un trucco elegante: la distribuzione di Laplace ha la forma $e^{-|x-\mu|/b}$, quindi il rapporto delle probabilità per due dataset adiacenti D e D' diventa $e^{\varepsilon \cdot (|q(D')-r|-|q(D)-r|)/GS_1}$. La **disuguaglianza triangolare** garantisce che $|q(D') - r| - |q(D) - r| \leq |q(D') - q(D)| \leq GS_1$, quindi il rapporto non supera mai e^ε – esattamente la garanzia DP.

Esempio: Conteggio Query

Sia $q(D) = n$ il numero totale di studenti.

- $GS_1(q) = 1$ (aggiungere/rimuovere un record cambia il conteggio di 1).
- $\tilde{n} = n + Lap(0, 1/\varepsilon)$.

Per rispondere a due query correlate $q_1(D) = n_c$ (studenti del corso) e $q_2(D) = n - n_c$ (non nel corso): per composizione $\tilde{n}_c = n_c + Lap(0, 1/\varepsilon)$ e $\tilde{n} - \tilde{n}_c$ è equivalente all'approccio diretto. Con composizione parallela su n_o (online) e n_c (fisici, insiemi disgiunti): $\tilde{n}_o = n_o + Lap(0, 1/\varepsilon)$ e $\tilde{n}_c = n_c + Lap(0, 1/\varepsilon)$; il totale $\tilde{n} = \tilde{n}_o + \tilde{n}_c$ per post-processing.

6.3 Meccanismo Esponenziale

Il meccanismo di Laplace non può essere usato in due casi:

- **Query non numeriche:** il meccanismo di Laplace aggiunge rumore numerico a $q(D)$, ma questo non ha senso quando $q(D)$ non è un numero (es. una stringa, una categoria).
- **Selezione DP:** quando q restituisce il valore $r \in R$ che massimizza una funzione di utilità U , un meccanismo additivo (come Laplace) può distruggere il risultato. Esempio: prezzo ottimo 3.01 con utilità 3.0; aggiungere 0.01 di rumore porta al prezzo 3.02 con utilità 0 (nessun cliente compra).

Definizione: Meccanismo Esponenziale

Per query con output categorici (non numerici). Sia R l'insieme dei possibili output, $U : \Omega \times R \rightarrow \mathbb{R}$ una funzione di utilità e $GS(U) = \max_{r \in R, D \sim D'} |U(D, r) - U(D', r)|$. Il meccanismo restituisce $r \in R$ con probabilità:

$$\mathbb{P}(\mathcal{M}(D, q) = r) \propto \exp\left(\frac{\varepsilon \cdot U(D, r)}{2 \cdot GS(U)}\right)$$

Preserva $\varepsilon/2$ -DP (o ε -DP a seconda della formulazione).

Nota: In parole semplici: Meccanismo Esponenziale

Quando la risposta non è un numero ma una categoria (es. "quale fascia di prezzo massimizza il profitto?", "quale parola suggerire?"), aggiungere rumore numerico non ha senso. Il meccanismo esponenziale risolve questo: invece di restituire sempre la risposta ottima, la *campiona* in modo casuale con probabilità proporzionale all'utilità – le risposte buone sono molto più probabili, quelle pessime quasi impossibili. Così non riveli il valore esatto del dataset, ma tendi comunque verso le risposte utili, preservando la DP.

6.4 Teoremi Fondamentali

Teorema: Post-Processing

Sia $\mathcal{M} : \Omega \rightarrow \mathcal{R}$ un meccanismo ε -DP e f una funzione con dominio $\mathcal{R}$. Allora $f \circ \mathcal{M}$ preserva la ε -differential privacy.

Implicazione: qualunque elaborazione dei risultati di un meccanismo DP non riduce la privacy (e non la aumenta). Non serve accedere ai dati originali.

Teorema: Composizione

Siano $\mathcal{M}_1$ e $\mathcal{M}_2$ due meccanismi che preservano rispettivamente ε_1 -DP e ε_2 -DP. Il meccanismo $\mathcal{N}(D) = (\mathcal{M}_1(D), \mathcal{M}_2(D))$ preserva $(\varepsilon_1 + \varepsilon_2)$ -DP.

Implicazione: più query consecutive consumano il privacy budget in modo additivo.

Teorema: Composizione Parallela

Sia $\mathcal{M} : \Omega \rightarrow \mathcal{R}$ un meccanismo ε -DP, e siano D_1, D_2 sottoinsiemi disgiunti di D (con $D_1 \cup D_2 = D$). Il meccanismo $\mathcal{N}(D) = (\mathcal{M}(D_1), \mathcal{M}(D_2))$ preserva ε -DP (non 2ε -DP).

Implicazione: applicare lo stesso meccanismo ε -DP su partizioni disgiunte del dataset non aumenta il budget consumato.

Nota: In parole semplici: Composizione e Budget

I tre teoremi di composizione si leggono così nella pratica:

- **Post-processing:** puoi elaborare liberamente l'output privato (calcolare medie, fare grafici, ecc.) senza perdere ulteriore privacy – perché non tocchi più i dati originali.
- **Composizione sequenziale:** se fai due query, ognuna con il suo budget ε , il budget totale consumato è $\varepsilon_1 + \varepsilon_2$. È come un conto corrente: ogni query preleva una quota.
- **Composizione parallela:** se invece le due query riguardano partizioni disgiunte del dataset (es. uomini e donne separatamente), il budget consumato è solo $\max(\varepsilon_1, \varepsilon_2)$ – non si sommano, perché ogni individuo appare in una sola partizione.

6.5 (ε, δ) -Differential Privacy

Definizione: (ε, δ) -DP

Versione rilassata della ε -DP. Un meccanismo $\mathcal{M}$ preserva (ε, δ) -DP se per ogni $D \sim D'$ e ogni $r \in \mathcal{R}$:

$$\mathbb{P}(\mathcal{M}(q, D) = r) \leq e^\varepsilon \cdot \mathbb{P}(\mathcal{M}(q, D') = r) + \delta$$

δ rappresenta la *probabilità di fallimento* del meccanismo. Quando $\delta = 0$ coincide con la ε -DP. La (ε, δ) -DP con $\delta > 0$ è **più debole** della ε -DP; δ deve essere il più piccolo possibile.

Teorema: $\mathcal{M}$ preserva (ε, δ) -DP se e solo se esiste un evento E con $\mathbb{P}(E) > 1 - \delta$ tale che $\mathcal{M}$ preserva ε -DP quando E si verifica.

Esempio: Perché δ deve essere piccolo – Due Meccanismi a Confronto

Sia $q(D)$ il numero di record di D . Si estrae casualmente $x \in (0, 1)$:

- **Meccanismo 1:** $\mathcal{M}(D) = q(D) + \text{Lap}(GS/\varepsilon)$ se $x \geq \delta$; altrimenti $\mathcal{M}(D) = D$ (rilascia l'intero dataset!).
- **Meccanismo 2:** $\mathcal{M}(D) = q(D) + \text{Lap}(GS/\varepsilon)$ se $x \geq \delta$; altrimenti $\mathcal{M}(D) = q(D)$ (rilascia il valore esatto).

Entrambi i meccanismi preservano (ε, δ) -DP, ma il Meccanismo 1 è **molto più pericoloso**: in caso di fallimento rilascia l'intero dataset privato. Questo dimostra che δ deve essere il più piccolo possibile e che **il modo in cui un meccanismo fallisce conta quanto**

la sua garanzia nominale. La composizione di più meccanismi (ε, δ) -DP richiede di sommare anche i parametri δ (come si fa per ε).

Teorema: Meccanismo Gaussiano

Per query vettoriali, usa il rumore Gaussiano:

$$\mathcal{M}_{Gauss}(q, D) \mapsto q(D) + \mathcal{N}(0, \sigma^2)$$

con $\sigma^2 = \frac{2 \cdot GS_2(q)^2 \cdot \ln(1.25/\delta)}{\varepsilon^2}$.

Preserva (ε, δ) -DP per $\varepsilon, \delta \in (0, 1)$.

$GS_2(q) = \max_{D \sim D'} \|q(D) - q(D')\|_2$ (sensibilità L2).

Confronto Laplace vs. Gaussiano:

- **Laplace** $\rightarrow \varepsilon$ -DP, sensibilità L1, qualsiasi $\varepsilon > 0$, meno rumore con stessa GS .
- **Gaussiano** $\rightarrow (\varepsilon, \delta)$ -DP, sensibilità L2, richiede $\varepsilon < 1$, migliore quando $GS_2 \ll GS_1$.

Confronto Entropia: il Gaussiano ha entropia $\frac{1}{2} \log(2\pi e \sigma^2)$; il Laplace ha entropia $\ln(\sqrt{2e}\sigma)$. Il Gaussiano ha entropia minore (meno rumore) a parità di σ .

6.6 Scenario Interattivo vs. Non-Interattivo

- **Interattivo:** il dataset rimane segreto; ogni analisi consuma una parte del budget ε . Il curatore è *fidato*.
- **Non-Interattivo:** si rilascia un dataset sintetico privato; ulteriori analisi sono libere (post-processing). Il dataset rilasciato deve già soddisfare la DP.

6.7 Curatore Non Fidato e Local Differential Privacy

Nota: Curatore non fidato

Tutti i meccanismi visti finora assumono che il **curatore sia fidato**: i dati grezzi vengono conferiti al curatore che aggiunge il rumore e rilascia il risultato. Ma cosa succede se il curatore non è fidato e gli utenti non vogliono che conosca i loro dati?

Soluzione: ogni utente inietta rumore *sui propri dati* e rivela solo la versione rumorosa al curatore. Il curatore riceve solo dati già privatizzati e non può risalire ai valori originali. Questo è il modello della **Local Differential Privacy (LDP)**, usabile anche in scenari decentralizzati.

Nota: In parole semplici: DP Globale vs. Locale

Nel modello **globale** (DP standard) ti fidi del curatore: mandi i tuoi dati veri al server centrale, che aggiunge il rumore prima di pubblicare i risultati. Nel modello **locale** (LDP) non ti fidi di nessuno: aggiungi tu stesso il rumore ai tuoi dati *prima* di inviarli – il server riceve già solo dati rumorosi e non può mai risalire al tuo valore originale. Il prezzo da pagare è che serve molto più rumore (e quindi molti più partecipanti) per ottenere statistiche accurate, ma si guadagna perché non occorre fidarsi del server centrale. Google usa LDP nel browser Chrome per raccogliere statistiche sull'uso delle funzionalità senza conoscere i comportamenti individuali.

6.8 Local Differential Privacy (LDP)

Definizione: (ε, δ) -Local DP

Un meccanismo $\mathcal{M}$ preserva (ε, δ) -LDP se per ogni query q , per ogni coppia di record $x, x' \in U$ (non solo dataset adiacenti) e per ogni $r \in \mathcal{R}$:

$$\mathbb{P}(\mathcal{M}(q, x) = r) \leq e^\varepsilon \cdot \mathbb{P}(\mathcal{M}(q, x') = r) + \delta$$

DP vs. LDP:

	DP	LDP
Indistinguibilità	Dataset adiacenti	Qualsiasi coppia di record
Curatore	Fidato	Non fidato
Rumore	Meno	Di più

Definizione: Randomized Response

Tecnica classica di sondaggi che preserva la LDP. Protocollo (rispondente a una domanda Sì/No):

1. Lanciare una moneta.
2. Se **Croce**: rispondere *verità*.
3. Se **Testa**: lanciare di nuovo e rispondere Sì (Testa) o No (Croce).

Probabilità: $P(\text{Sì}|\text{vero}=\text{Sì}) = 3/4$; $P(\text{No}|\text{vero}=\text{Sì}) = 1/4$.

Il Randomized Response preserva $\log(3)$ -DP (LDP).

Prova: Il rapporto massimo è $\frac{3/4}{1/4} = 3 = e^{\log 3}$.

Nota: In parole semplici: Randomized Response

È la tecnica classica usata nei sondaggi su domande imbarazzanti (es. “Hai mai usato droghe?”). Prima di rispondere, lanci una moneta in segreto: se viene croce, rispondi la verità; se viene testa, lanci di nuovo e rispondi Sì o No a caso. Così il ricercatore non sa mai se la tua risposta è vera o casuale – la tua privacy è protetta. Ma conoscendo la probabilità della moneta, il ricercatore può *correggere statisticamente* le risposte e stimare la frequenza reale del comportamento nell’intera popolazione. La DP è garantita perché il rapporto tra la probabilità di dire Sì quando sei davvero Sì (3/4) e la probabilità di dirlo quando sei No (1/4) è $3 = e^{\log 3}$, quindi soddisfa $\log(3)$ -LDP.

Definizione: Randomized Response Generalizzato

Per k valori categorici possibili, con $v \in \{v_1, \dots, v_k\}$:

$$P(\mathcal{M}(q, x) = v) = \begin{cases} \frac{e^\varepsilon}{e^\varepsilon + k - 1} & \text{se } q(x) = v \\ \frac{1}{e^\varepsilon + k - 1} & \text{altrimenti} \end{cases}$$

Preserva ε -LDP. Per dati numerici: usare Laplace/Gaussiano con $GS_1(q) = \max_{x, x' \in U} \|q(x) - q(x')\|_1$.

6.9 Machine Learning e Differential Privacy

Negli ultimi anni sono stati sviluppati numerosi algoritmi di Machine Learning **differenzialmente privati**. L'idea di base del **DP Machine Learning** è iniettare rumore nella *fase di training* del modello ML, al fine di nascondere la presenza di un particolare record nel training set.

Nota: Obiettivo Comune di ML e DP

È importante che un modello di Machine Learning non dipenda eccessivamente dai dati di training (per evitare l'overfitting). In questo senso, ML e DP condividono un obiettivo comune: restituire risultati accurati che **non dipendano dalla presenza di un individuo specifico nei dati**. La DP formalizza questa garanzia in modo rigoroso, mentre il ML la persegue per motivi di generalizzazione.

7 Privacy in Sistemi Distribuiti

7.1 Il Problema

L'approccio tradizionale di raccogliere tutti i dati in un data warehouse centrale non funziona in un contesto distribuito per motivi di privacy. Creare un algoritmo di data mining/ML che estrae dati direttamente dalle sorgenti locali non risolve il problema: tutti gli ostacoli che impedivano la creazione del data warehouse rimangono, semplicemente incorporati nello strumento di mining.

Chi ha bisogno di analisi distribuite private?

- **Enti governativi e pubblici:** i Centers for Disease Control vogliono identificare focolai di malattia; le compagnie assicurative hanno dati su incidenti, gravità e background dei pazienti, ma non possono/devono rilasciarli liberamente.
- **Collaborazioni industriali:** un consorzio di settore vuole identificare le best practice tra i membri, ma alcune pratiche sono segreti commerciali. Come fornire risultati "comuni" mantenendo i segreti?
- **Multinazionali:** un'azienda vuole estrarre modelli globalmente validi dai propri dati, ma le leggi nazionali impediscono il trasferimento transfrontaliero.
- **Uso pubblico di dati privati:** le big data analytics permettono studi su popolazioni ampie, ma le popolazioni sono riluttanti a rilasciare informazioni personali.

Classi di soluzione:

- **Data Obfuscation:** nessuno vede i dati reali.
- **Sommarizzazione:** solo i fatti necessari sono esposti.
- **Data Separation:** solo parti fidate vedono i dati. Approcci: i dati rimangono presso il proprietario/creatore; rilascio limitato a terze parti fidate; operazioni/analisi eseguite dalla parte fidata. Problemi: la parte fidata sarà disposta a fare l'analisi? I risultati dell'analisi divulgano informazioni private?

7.2 Secure Multiparty Computation (SMC)

Definizione: SMC

L'obiettivo è calcolare una funzione quando ogni parte ha qualche input, senza che nessuna parte impari più del necessario.

Problema dei Milionari (Yao): Alice e Bob vogliono sapere chi è più ricco senza rivelare il proprio patrimonio.

Definizione: Oblivious Transfer (OT) 1-of-2

È il blocco crittografico fondamentale che permette di risolvere il Problema dei Milionari senza una terza parte fidata. Prende in considerazione due parti:

- **Alice (Sender):** ha una coppia di input privati (m_0, m_1) (correlati alle chiavi di cifratura).
- **Bob (Receiver):** ha un bit privato $b \in \{0, 1\}$ (selection bit) che specifica quale dei due messaggi vuole leggere.

Il protocollo consente a Bob di ottenere m_b tramite la formula:

$$m_b = (1 \oplus b) m_0 \oplus b m_1$$

(se $b = 0$: $m_b = m_0$; se $b = 1$: $m_b = m_1$).

Proprietà di sicurezza:

- **Sicurezza del Sender:** un receiver corrotto non deve apprendere alcuna informazione aggiuntiva oltre al messaggio che vuole ricevere; se legge m_0 , non deve poter leggere m_1 (sarà illeggibile con la chiave ricevuta).
- **Sicurezza del Receiver:** un sender corrotto non deve apprendere nulla sul valore di b . Questo è il motivo per cui il protocollo è detto *oblivious* (ignaro): il messaggio corretto viene inviato, ma non direttamente, e il sender non sa quale dei due messaggi è stato letto.

Nota: In parole semplici: Oblivious Transfer

Pensa all'OT come a una cassetta della posta magica con due scomparti: Alice inserisce m_0 nel primo scomparto e m_1 nel secondo. Bob può aprire *solo uno* dei due scomparti (quello corrispondente al suo bit b), ma Alice non sa quale ha aperto. È "oblivious" (cieco) perché il mittente è all'oscuro di quale messaggio è stato ricevuto, e il ricevente non riesce a leggere l'altro. Questo blocco crittografico è il fondamento del calcolo sicuro: usando OT si può valutare privatamente qualsiasi operazione logica (AND, XOR, NOT) e quindi qualsiasi funzione arbitraria, senza che nessuna delle due parti impari gli input dell'altra.

Esempio: OT 1-of-2 per computare l'AND sicuro di due bit

Alice vuole calcolare $x_1 \cdot x_2$ (AND) con Bob senza rivelare i propri input. Alice (sender) pone $m_0 = 0$ e $m_1 = x_1$; Bob (receiver) usa $b = x_2$. Allora:

$$m_b = (1 \oplus x_2) \cdot 0 \oplus x_2 \cdot x_1 = x_2 \cdot x_1$$

Bob ottiene $x_1 \cdot x_2$ senza che Alice sappia x_2 , e senza che Bob sappia x_1 . Questo è il meccanismo alla base della valutazione sicura dei gate AND nei garbled circuit di Yao.

OT 1-of-N da OT 1-of-2 (per $N=2^k$ messaggi): Alice sceglie k coppie di chiavi casuali (una per ogni bit dell'indice del messaggio desiderato) e cifra ogni messaggio m_{ij} con la coppia corrispondente: $c_{ij} = F_{k'_i}(ij) \oplus F_{k_j}(ij) \oplus m_{ij}$. Bob usa k OT 1-of-2 per ottenere le chiavi giuste e decifra solo il messaggio selezionato.

Oblivious Polynomial Evaluation: il sender ha un polinomio Q di grado k ; il receiver ha un valore z ; il receiver ottiene $Q(z)$ senza che il sender sappia z e senza che il receiver impari i coefficienti di Q . Overhead: $O(k)$ esponenziali.

7.2.1 Protocollo di Yao per Due Parti

Teorema: Protocollo di Yao (Garbled Circuit)

Protocollo a **round costante** (2 round) per il calcolo sicuro di funzioni arbitrarie.

1. Alice crea un **garbled circuit** (circuit o oblioso): per ogni gate del circuito, le tavole di verità sono cifrate.
2. Alice manda il garbled circuit a Bob insieme ai garbled values per i propri input.
3. Bob usa OT per ottenere i garbled values per i propri input y senza che Alice sappia y .
4. Bob valuta il circuito e ottiene l'output.

Overhead: $O(\text{circuito}) + O(|y|)$ OT. Modello di sicurezza: semi-honest.

Nota: In parole semplici: Garbled Circuit di Yao

L'idea è di "cifrare" un circuito logico in modo che si possa valutare senza vedere gli input. Alice codifica ogni filo del circuito con una coppia di chiavi segrete (una per il valore 0, una per l'1) e cifra le tavole di verità di ogni gate con queste chiavi – così il gate produce il risultato corretto solo se si hanno le chiavi giuste per quell'input, senza rivelare la tavola di verità in chiaro. Bob riceve il circuito "oscurato" e, tramite OT, ottiene le chiavi corrispondenti ai propri input senza che Alice sappia quali ha scelto. Bob valuta poi il circuito gate per gate: in ogni gate prova a decifrare le quattro entry finché una ha successo, ottenendo la chiave di output – senza mai vedere la tavola di verità. Il modello **semi-honest** assume che entrambe seguano il protocollo correttamente ma possano osservare i messaggi intermedi.

Esempio: Soluzione del Problema dei Milionari tramite Secret Sharing

Per risolvere il Problema dei Milionari, i valori patrimoniali sono convertiti in stringhe binarie. Le parti valutano un circuito di confronto ("greater-than") gate per gate: $(A \oplus B) \cdot A$.

Secret Sharing: ogni bit viene suddiviso in due *share* casuali: $A = a_1 \oplus a_2$ e $B = b_1 \oplus b_2$, dove Alice aggiunge un bit casuale c_1 . I valori segreti binari vengono suddivisi in pezzi casuali (a_i, b_i) che possono essere combinati tramite $\oplus$ (addizione modulo 2).

Come funziona:

- Ogni parte aggiunge un valore casuale al proprio input e lo passa all'altra: entrambe hanno una *share* di tutti gli input.
- Ogni parte calcola la propria share dell'output; le share vengono combinate alla fine.

- **Gate XOR:** calcolato localmente (addizione modulo 2).
- **Gate AND:** si invia la propria share codificata nella OT-table; l'OT permette all'altra parte di ottenere solo il valore corretto.

OT-table per il gate AND (valori di output c_2 per Bob, dato input (a_2, b_2)):

Valore di Bob (a_2, b_2)	OT-input (Alice)	Valore di c_2
(0, 0)	1	$c_1 \oplus a_1 b_1$
(0, 1)	2	$c_1 \oplus a_1(b_1 \oplus 1)$
(1, 0)	3	$c_1 \oplus (a_1 \oplus 1)b_1$
(1, 1)	4	$c_1 \oplus (a_1 \oplus 1)(b_1 \oplus 1)$

Perché funziona: l'obiettivo è che $c_1 \oplus c_2 = (a_1 \oplus a_2) \cdot (b_1 \oplus b_2)$. Scegliendo il corretto OT-input, la maschera c_1 si cancella, lasciando share valide del risultato dell'AND. Esempio: se $(a_2, b_2) = (1, 1)$, Bob seleziona il 4° valore: $c_2 = c_1 \oplus (a_1 \oplus 1)(b_1 \oplus 1)$; combinando: $c_1 \oplus c_2 = (a_1 \oplus 1)(b_1 \oplus 1) = (a_1 \oplus a_2)(b_1 \oplus b_2)$.

7.2.2 Privacy Preserving ID3

ID3 Algorithm (Quinlan): costruisce un decision tree usando information gain.

1. Calcola il guadagno di informazione per ogni feature.
2. Splitta il dataset sulla feature con minima entropia (massimo IG).
3. Crea un nodo decisionale. Ripeti ricorsivamente per i sottoalberi.
4. Se tutte le righe hanno la stessa classe, crea una foglia.

Definizione: ID3_δ – Lindell & Pinkas, J. Cryptology 2002

Protocollo per ID3 su dati distribuiti orizzontalmente tra due parti (stessa schema, attributi pubblici, entità individuali private). Computa un'approssimazione di ID3 chiamata ID3_δ.

Assunzioni e limitazioni:

- Modello *semi-honest* (honest-but-curious): ogni parte segue correttamente il protocollo ma conserva un registro di tutti i calcoli intermedi.
- Solo il caso a **due parti**; l'estensione a più parti non è banale.
- Calcola ID3_δ: qualsiasi implementazione di ID3 che calcola la funzione logaritmo a una precisione predefinita ha un errore δ . ID3_δ usa un'approssimazione dell'Information Gain che non richiede il calcolo del logaritmo e migliora l'efficienza; computa l'insieme degli alberi con attributi ai nodi che differiscono per $IG < \delta$.
- Gestisce solo **attributi categorici**.

Tre passi principali:

1. **Classe più frequente:** se l'insieme attributi A è vuoto, restituisce nodo foglia con la classe assegnata alla maggioranza delle transazioni in D . L'insieme degli attributi è pubblico (entrambe sanno se A è vuoto). Si esegue il protocollo di Yao con input $(|D_1(c_1)|, \dots, |D_1(c_L)|)$ e $(|D_2(c_1)|, \dots, |D_2(c_L)|)$; output: i tale che $|D_1(c_i)| +$

$|D_2(c_i)|$ sia massimo. Complessità proporzionale al numero di classi e al logaritmo del numero di esempi.

2. **Verifica foglia:** se D ha tutti esempi con la stessa classe c , restituisce foglia con valore c . Per computare privatamente: si usa un simbolo fisso diverso dai c_i per nodi non puri; le parti inseriscono tale simbolo o c_i ; si verifica l'uguaglianza (tramite Yao o OT).

3. **Attributo migliore:**

- (a) Determina l'attributo A_i che meglio classifica D : calcolato calcolando in modo sicuro $x \cdot (\ln x)$. Il protocollo di Yao restituisce share casuali di n e ε tali che $x = 2^n(1+\varepsilon)$ con $-\frac{1}{2} < \varepsilon < \frac{1}{2}$; allora $n \ln 2$ è la stima grezza di $\ln x$ e $\ln(1+\varepsilon)$ il "remainder" approssimato tramite serie di Taylor (valutazione di un polinomio intero con circuiti semplici).
- (b,c) Chiama ricorsivamente $ID_{3\delta}$ sugli insiemi $D(a_1), \dots, D(a_m)$ dove $a_1, \dots, a_m$ sono i valori di A_i . Poiché i risultati di (a) e i valori degli attributi sono pubblici, entrambe le parti partizionano il database autonomamente.

7.3 Altri Approcci

- **Functional encryption:** generalizzazione della crittografia a chiave pubblica; decriptare rivela solo una funzione del plaintext.
- **Homomorphic encryption:** crittografia che permette di effettuare calcoli su dati cifrati senza decriptarli; i risultati sono in forma cifrata. Computazionalmente costosa.
- **Federated learning:** consente di allenare un algoritmo su molti dispositivi decentralizzati senza effettuare scambi di dati grezzi; solo i gradienti (o parametri) del modello vengono condivisi.

Nota: In parole semplici: Altri Approcci alla Privacy Distribuita

- **Crittografia funzionale:** invece di dover decriptare l'intero messaggio, una chiave speciale permette di calcolare solo una funzione specifica del testo in chiaro (es. la media degli stipendi di tutti, senza vedere i singoli valori). Generalizza la crittografia tradizionale a chiave pubblica.
- **Crittografia omomorfa:** puoi eseguire calcoli direttamente sui dati *cifrati* – il risultato decifrato coincide con quello che avresti ottenuto operando sui dati in chiaro. Concettualmente potente, ma attualmente è molto lenta (ordini di grandezza rispetto al calcolo normale); usata in scenari dove la privacy è prioritaria rispetto alle prestazioni.
- **Federated learning:** ogni dispositivo (es. il tuo smartphone) allena il modello ML localmente sui propri dati e manda solo il *gradiente* (ovvero "in che direzione modificare i parametri del modello") al server centrale. Il server aggrega i gradienti di tutti gli utenti e aggiorna il modello globale. I dati grezzi non lasciano mai il dispositivo locale – è la tecnica usata ad esempio da Google per migliorare la tastiera Gboard senza accedere ai tuoi messaggi.

8 Fairness e Discriminazione

8.1 Introduzione alla Fairness

Definizione: Metodo Clinico vs. Attuariale

- **Metodo Clinico:** il decisore combina o elabora le informazioni nella sua mente. Un metodo IA clinico si basa su una serie di regole prestabilite fornite da un esperto del settore (sistemi esperti). Usato prevalentemente dal 1956 al 1990.
- **Metodo Attuariale/Statistico:** le conclusioni si basano esclusivamente su relazioni empiricamente stabilite tra i dati e la condizione o l'evento di interesse. Un metodo IA attuariale esamina i dati passati per prevedere i risultati futuri (machine learning, deep learning). Dal 1980 ad oggi.

Definizione: Bias – Concetto Generale

Il termine **bias** (pregiudizio/distorsione) indica una tendenza sistematica che porta a risultati distorti o ingiusti. Nel contesto dell'IA e del machine learning si distinguono due accezioni:

- **Bias statistico/di apprendimento:** errore sistematico nella stima di una quantità. Un modello che fa assunzioni troppo semplici rispetto alla realtà ha alto bias (underfitting). Formula: $\text{Errore} = \text{Bias}^2 + \text{Varianza} + \text{Rumore irreducibile}$.
- **Bias di discriminazione:** tendenza sistematica di un algoritmo a produrre decisioni sfavorevoli per determinati gruppi (razza, genere, religione, ecc.) anche in assenza di intenzione esplicita.

Fonti di bias nei sistemi ML:

1. **Bias nei dati storici:** i dati di training riflettono discriminazioni passate (es. dati di assunzione da aziende che storicamente escludevano donne).
2. **Bias di misurazione:** le variabili nel dataset non catturano accuratamente il fenomeno reale per tutti i gruppi.
3. **Bias di campionamento:** il training set non è rappresentativo di tutti i gruppi su cui il modello opererà.
4. **Bias di aggregazione:** il modello ignora differenze importanti tra sottogruppi.
5. **Proxy attributes:** attributi apparentemente neutri (codice postale, nome) correlati ad attributi sensibili.

Rischi etici: un sistema ML con bias di discriminazione può perpetuare e amplificare le disuguaglianze esistenti – il *feedback loop*: dati distorti → modello distorto → decisioni distorte → nuovi dati ancora più distorti.

Esempi di bias nel ML:

- Google Photos classifica afroamericani come gorilla.
- Algoritmo IA per concorsi di bellezza: preferisce persone di pelle chiara.
- Modelli di predizione dei crimini (COMPAS): assegna punteggi di rischio più alti ad afroamericani.

- Modelli di scraping AI mostrano discriminazione nei confronti delle donne.
- Amazon abbandona un modello di selezione del personale che discriminava le donne.
- Negli USA persone con nomi “tipicamente bianchi” ricevono più colloqui di lavoro.

Problema fondamentale: L’IA attuariale è spesso *opaca*: è difficile capire perché un sistema ha preso una particolare decisione. Sebbene sia possibile ispezionare i parametri di un modello, collegare questi parametri alle ragioni effettive delle decisioni è difficile.

8.2 Machine Learning e Fairness

Definizione: Classificazione

La classificazione è il processo di determinare un valore plausibile per Y dato X , dove X sono i dati/covariati e Y sono i valori target. Si apprende $f_\theta : X \rightarrow \hat{Y}$.

Accuratezza: $P(Y = \hat{Y})$.

Classificatore ottimale: minimizza $\mathbb{E}[l(Y, \hat{Y})]$ (valore atteso del costo). Equivalentemente: $\hat{Y} = f(X)$ dove $f(X) = 1$ se $\mathbb{P}(Y = 1|X = x) > 1/2$, altrimenti 0.

Definizione: Ciclo ML

Stato del Mondo $\xrightarrow{\text{Measurement}}$ Data $\xrightarrow{\text{Learning}}$ Model $\xrightarrow{\text{Action}}$ Individuals $\xrightarrow{\text{Feedback}}$ Stato del Mondo.

- **Misurazione:** il processo in cui lo stato del mondo viene ridotto a tabelle di dati. Alcune caratteristiche possono essere non osservabili (necessità di un modello di misurazione).
- **Apprendimento:** ricerca di buoni parametri θ per f .
- **Azioni:** come vengono impiegate le decisioni su input nuovi.
- **Feedback:** registrazione delle reazioni degli utenti.

Problemi di bias nel ciclo: dati sufficienti per tutti i gruppi? Le misurazioni non sono di parte? L’assunzione di indipendenza degli errori è probabilmente falsa tra gruppi.

8.3 Discriminazione e Misure di Discriminazione

Definizione: Discriminazione Diretta

La pratica di trattare in modo diverso le persone in base alla loro appartenenza a un gruppo sociale rilevante. Nell’UE è disciplinata dall’Art.21 della Carta dei Diritti Fondamentali.

Definizione: Discriminazione Indiretta

La pratica di offrire lo stesso trattamento a persone appartenenti a gruppi sociali distinti se ciò comporta che un gruppo di persone sia posto in una situazione di particolare svantaggio.

Esempio: pensioni calcolate in modo uguale per part-time e full-time; poiché l’88% dei part-time erano donne, l’effetto era sproporzionatamente negativo per le donne (caso Hilde Schönheit vs. Frankfurt).

Cosa rende sbagliata la discriminazione?

- *Animosità sistematica*: intenzione ostile verso determinati gruppi – ma gli algoritmi non hanno intenzioni.
- *Fare inferenze sugli individui basate sui gruppi di cui fanno parte*: trattare le persone come categorie, non come individui.

8.3.1 Egalitarismo

Definizione: Egalitarismo

L'idea che le persone debbano essere trattate in modo uguale e che alcune cose di valore debbano essere distribuite equamente.

- Cohen: piacere o soddisfazione delle preferenze.
- Rawls & Dworkin: reddito e beni.
- Sen: capacità e risorse necessarie per fare determinate cose.

Tipi di danni algoritmici:

- **Allocativi**: a determinati gruppi vengono negate risorse in modo disparato (COMPAS, sistema di assunzione di Amazon).
- **Rappresentativi**: viene rafforzata la subordinazione di alcuni gruppi (beauty.ai, traduzione automatica).

Definizione: Inconsapevolezza – Fairness through Unawareness

L'inconsapevolezza di solito non esiste nei dati del mondo reale ed è difficile da sostenere: correlazioni tra attributi innocui e attributi sensibili permettono ai modelli di “recuperare” informazioni sensibili anche senza usarle esplicitamente.

8.3.2 Criteri di Fairness (Metriche)

Siano X covariate, Y variabile target, $\hat{Y}$ la stima del classificatore f_θ , R il punteggio di rischio, A l'attributo sensibile (es. razza, genere).

Definizione: Indipendenza (Demographic Parity)

Le variabili casuali $(\hat{Y}, A)$ soddisfano l'indipendenza se $\hat{Y} \perp A$, ovvero:

$$\mathbb{P}(\hat{Y} = 1 \mid A = a) = \mathbb{P}(\hat{Y} = 1 \mid A = b)$$

Versione rilassata (con $\varepsilon \geq 0$):

$$\frac{\mathbb{P}(\hat{Y} = 1 \mid A = a)}{\mathbb{P}(\hat{Y} = 1 \mid A = b)} \geq 1 - \varepsilon$$

Problema: l'indipendenza può essere soddisfatta con decisioni malintenzionate (assumere dal gruppo b casualmente con probabilità p mentre dal gruppo a con merito $p \Rightarrow$ gruppo b ha risultati peggiori).

Definizione: Separazione (Equal Error Rates)

Le variabili casuali $(\hat{Y}, A, Y)$ soddisfano la separazione se $\hat{Y} \perp A \mid Y$.

La separazione può essere intesa come **parità del tasso di errore tra i gruppi**: il classificatore commette errori con la stessa frequenza nei vari gruppi.

Definizione: Sufficienza (Calibration)

Le variabili casuali $(\hat{Y}, A, Y)$ soddisfano la sufficienza se $Y \perp A \mid \hat{Y}$.

La sufficienza riflette la **calibrazione**: la previsione del modello è ugualmente affidabile per tutti i gruppi.

Nota: In parole semplici: Criteri di Fairness

- **Indipendenza (Demographic Parity)**: il modello deve approvare la stessa percentuale di richieste in ogni gruppo – es. stessa percentuale di prestiti concessi a uomini e donne, indipendentemente dal merito individuale. Problema: può portare a assumere “a caso” dal gruppo svantaggiato.
- **Separazione (Equal Error Rates)**: il modello può sbagliare, ma deve sbagliare con la *stessa frequenza* per tutti i gruppi. Esempio: il sistema COMPAS deve avere lo stesso tasso di falsi positivi (etichettare come “ad alto rischio” chi non lo è) per bianchi e afroamericani.
- **Sufficienza (Calibration)**: se il modello predice “70% di rischio di recidiva”, quel 70% deve essere ugualmente valido per bianchi e afroamericani – il punteggio deve essere ugualmente affidabile per tutti i gruppi, indipendentemente dall’attributo sensibile.

Il **teorema di incompatibilità** dice che, in quasi tutti i contesti reali (dove A e Y sono correlati), non si possono soddisfare contemporaneamente tutti e tre i criteri: bisogna scegliere quale garanzia è più importante e accettare di violare le altre. Non esiste una definizione universale di “fairness”.

Teorema: Teoremi di Incompatibilità

Se A e Y **non sono indipendenti** (il che è quasi sempre vero in contesti reali), allora:

- **Separazione e Indipendenza non possono essere entrambe vere simultaneamente** (a meno di casi degeneri).
- **Sufficienza e Indipendenza non possono essere entrambe vere simultaneamente** (a meno di casi degeneri).

Questi risultati mostrano che non è possibile soddisfare contemporaneamente tutti i criteri di fairness desiderabili.

8.3.3 Interventi di Fairness

- **Pre-processing**: cambiare i dati di input (X) o i target (Y) o entrambi prima del training.
- **In-processing**: cambiare il processo di learning f_θ (aggiungere vincoli o penalizzazioni al training).

- **Post-processing:** cambiare $\hat{Y}$ dopo che il modello è stato addestrato.

Definizione: Soppressione per Fairness

Trovare le caratteristiche in X che sono correlate con le informazioni sensibili A e rimuoverle. Una nozione più generale è la **mutua informazione di Shannon**.